



RELATÓRIO INDIVIDUAL PRELIMINAR

SETD - Secretaria de Estado de Transformação Digital

1. Introdução

Este relatório apresenta os resultados preliminares da organização **SETD** relativos à Fiscalização TCE-RJ nº 18/2026, realizada pelo TCE-RJ entre fevereiro e junho de 2026 para avaliar o grau de adoção de práticas de governança e gestão de tecnologia da informação e comunicação pelas organizações jurisdicionadas.

O trabalho abrangeu órgãos e entidades de todos os poderes da Administração Pública Estadual e um conjunto de prefeituras municipais.

2. iGovTI 2026

A avaliação das organizações jurisdicionadas baseia-se no método de autoavaliação de controles (*Control Self-Assessment* – CSA), operacionalizado mediante questionário eletrônico. A ferramenta permitiu aos gestores declarar o nível de adoção das práticas de tecnologia da informação avaliadas e encaminhar a documentação probatória correspondente. As evidências anexadas e as justificativas apresentadas foram submetidas à análise de consistência por esta Equipe de Auditoria, servindo de subsídio para eventuais ajustes na pontuação declarada e para a identificação de inconformidades ou achados de auditoria.

O questionário do iGovTI 2026 foi estruturado com o objetivo de diagnosticar aspectos essenciais de governança e gestão de TIC, abrangendo segurança da informação, gestão de riscos, continuidade de negócios, serviços de tecnologia, contratações de TIC, estrutura e força de trabalho, desenvolvimento de soluções, gestão de projetos e temas emergentes, a exemplo do uso de inteligência artificial. Para além do diagnóstico situacional de cada organização, o instrumento serve como referencial metodológico para futuras ações de melhoria de gestão.

O iGovTI 2026 constitui um índice composto, mensurado em uma escala de 0 a 1. A quantificação do índice inicia-se com a conversão das respostas categóricas declaradas em coeficientes numéricos, conforme os critérios de valoração estabelecidos na Tabela 1.

Tabela 1 - Critérios de valoração das respostas qualitativas do questionário iGovTI 2026

Categoria de Resposta Declarada	Coefficiente Numérico
Não adota	0,00
Há decisão formal ou plano aprovado para adotá-lo	0,05
Adota em menor parte	0,15
Adota parcialmente	0,50

Categoria de Resposta Declarada	Coefficiente Numérico
Adota em maior parte ou totalmente	1,00

(Fonte: elaboração própria)

Nas questões que admitem itens de detalhamento, a pontuação da questão principal sofre deduções proporcionais à quantidade de itens não atendidos pela organização. Subsequentemente, os valores são consolidados por meio de agregação ponderada em uma estrutura hierárquica. O índice final é composto por dois blocos principais, conforme detalhado na Figura 1: **Governança de TIC (peso de 47,8%)**, formado por 4 questões de agregação direta; **Gestão de TIC (iGestTI) (peso de 52,2%)**, estruturado em 6 dimensões operacionais que consolidam 20 questões principais ponderadas.

Figura 1 - Composição do iGovTI 2026



(Fonte: elaboração própria)

Com base na pontuação consolidada do iGovTI 2026, a organização é classificada em um de quatro níveis de maturidade, cujos intervalos de pontuação estão definidos na Tabela 2 e representados graficamente na parte inferior da Figura 1.

Tabela 2 - Intervalos de pontuação para enquadramento nos níveis de maturidade

Nível de Maturidade	Intervalo do Índice (iGovTI)
Inexpressivo	$0,00 \leq \text{iGovTI} < 0,15$
Iniciando	$0,15 \leq \text{iGovTI} < 0,40$

Nível de Maturidade	Intervalo do Índice (iGovTI)
Intermediário	$0,40 \leq \text{iGovTI} < 0,70$
Aprimorado	$0,70 \leq \text{iGovTI} \leq 1,00$

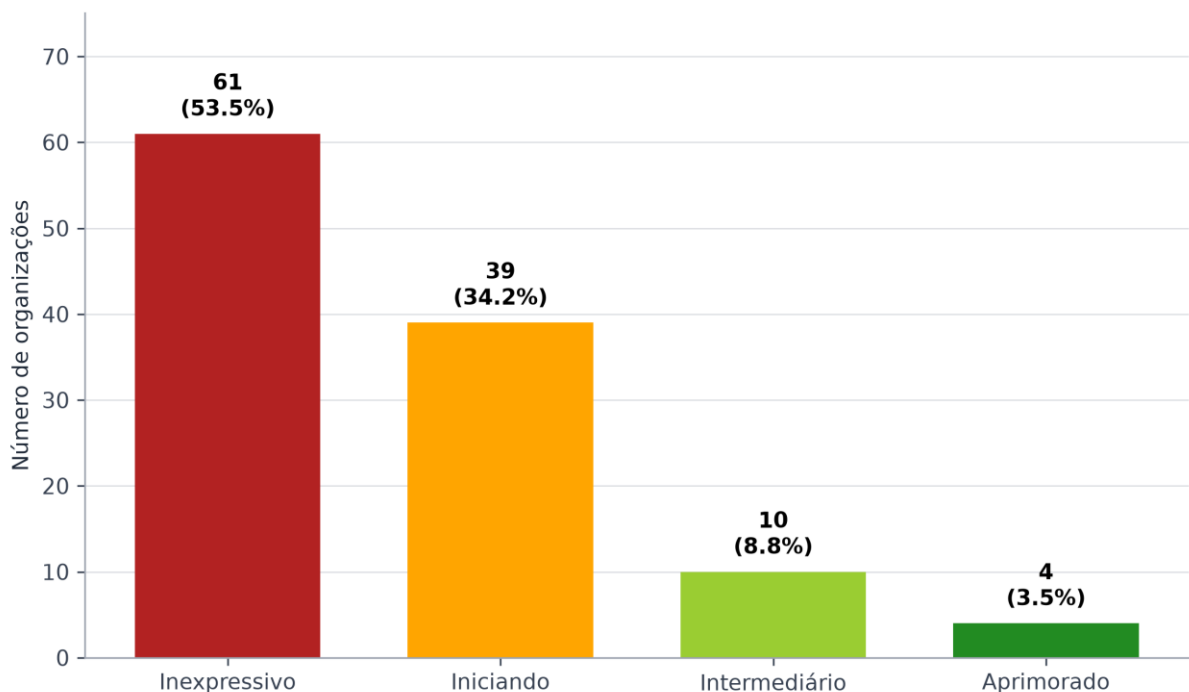
(Fonte: elaboração própria)

2.1. Cenário Geral

A análise consolidada apresentada nesta seção fundamenta-se nos resultados calculados para as 114 organizações que integram o universo amostral da fiscalização. A análise visa contextualizar o resultado individual da organização **SETD**, identificar padrões de maturidade, assimetrias entre governança e gestão e capacidades desenvolvidas no conjunto avaliado.

A distribuição por nível de maturidade, apresentada na Figura 2, evidencia concentração nos estágios iniciais. Das 114 organizações, 61 (53,5%) foram classificadas no nível **Inexpressivo** e 39 (34,2%) no nível **Iniciando**. Assim, 100 organizações (87,7%) obtiveram resultado inferior a 0,40. Somente 10 organizações (8,8%) alcançaram o nível **Intermediário** e 4 (3,5%) o nível **Aprimorado**.

Figura 2 - Distribuição das organizações por nível de maturidade do iGovTI 2026



(Fonte: elaboração própria)

O iGovTI apresentou média de 0,187 e mediana de 0,135. O primeiro quartil foi 0,066 e o terceiro quartil, 0,235, o que evidencia a concentração de 50% das organizações avaliadas nesse intervalo, bem como a permanência de pelo menos 75% das entidades

abaixo do nível Intermediário. A divergência positiva entre a média e a mediana, combinada com o valor máximo de 0,777 e com apenas 4 organizações no nível Aprimorado, caracteriza uma distribuição com assimetria à direita (positiva): um grupo reduzido de resultados elevados desloca a média para cima, sem alterar o quadro predominante de baixa maturidade. 5 organizações apresentaram valor igual a zero no índice calculado.

A distribuição contínua da Figura 3 complementa a classificação por faixas e permite observar a concentração dos resultados, os limites de maturidade e a distância entre a mediana e os valores mais elevados.

Figura 3 - Distribuição contínua dos resultados do iGovTI 2026



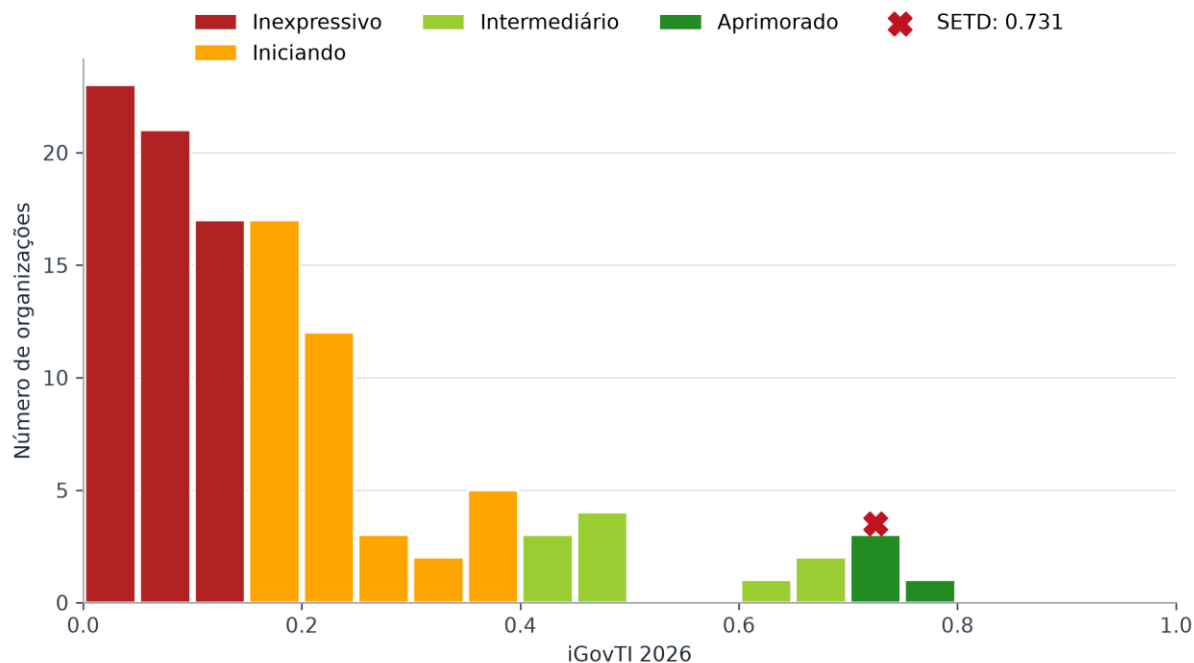
(Fonte: elaboração própria)

A posição específica da organização **SETD** nessa distribuição pode ser observada na Figura 4. Diferenças marginais de pontuação entre organizações adjacentes no ranking devem ser interpretadas com cautela analítica, visto que o modelo matemático de composição do índice não pressupõe estimativa de erro amostral e que os resultados estão sujeitos à qualidade e à fidedignidade declaratória do jurisdicionado.

2.2. Cenário atual - SETD

Apresentado o panorama geral do universo fiscalizado, esta subseção detalha o desempenho específico da organização jurisdicionada. A organização **SETD** obteve o **valor 0,7306 para o iGovTI 2026**, correspondente ao nível **Aprimorado** de maturidade.

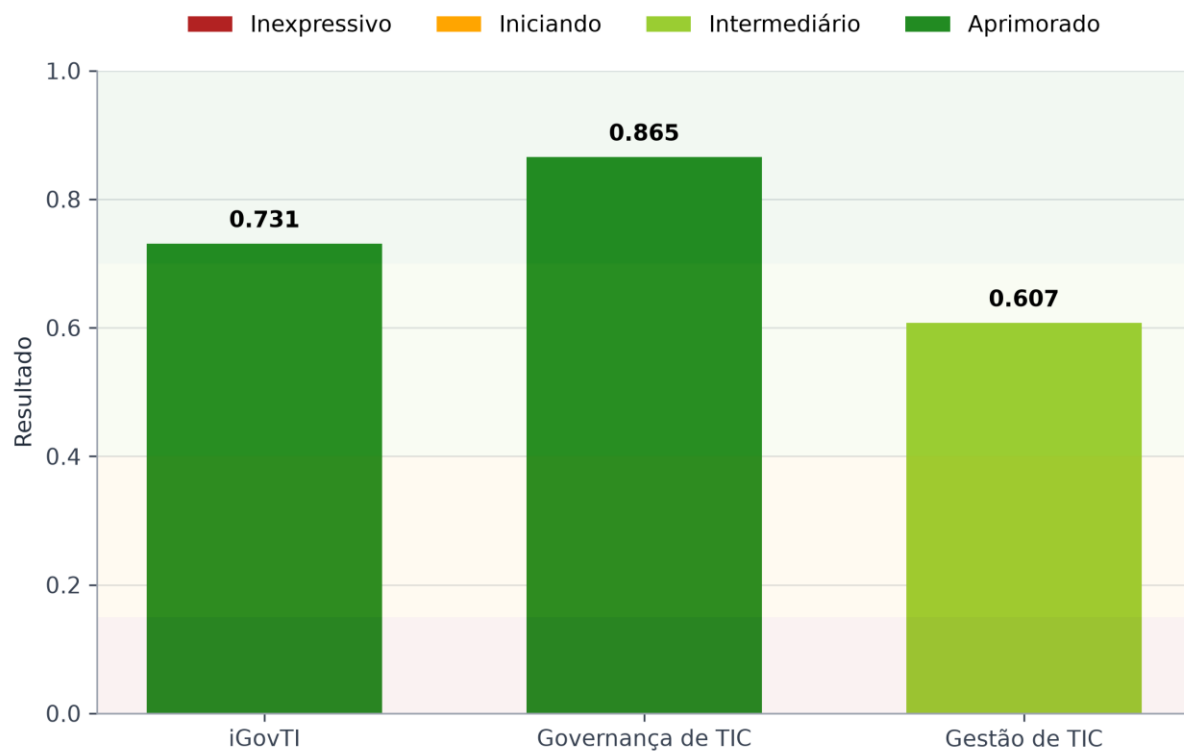
Figura 4 - Distribuição dos resultados do iGovTI 2026 e posição da organização SETD



(Fonte: elaboração própria)

A Figura 5 apresenta a composição do resultado da organização **SETD** entre governança e gestão de TIC.

Figura 5 - Resultado da organização SETD por componentes do iGovTI 2026



(Fonte: elaboração própria)

Tabela 3 - Resultado sintético do iGovTI 2026 da organização SETD

Componente	Peso no iGovTI 2026	Valor
Governança de TIC	0,4777	0,8654
Gestão de TIC	0,5223	0,6074
iGovTI 2026	1,0000	0,7306

(Fonte: elaboração própria)

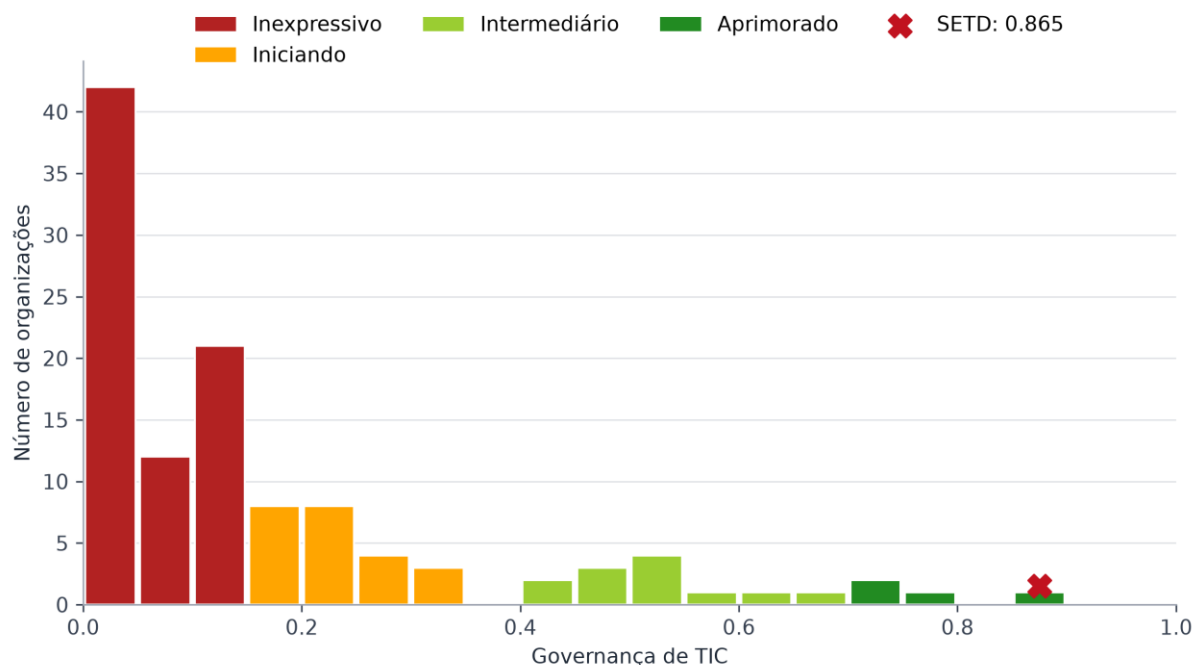
2.2.1. Governança de TIC

A governança de TIC avalia a capacidade da alta administração de orientar, dirigir, monitorar e controlar o uso da tecnologia da informação, de modo alinhado aos objetivos institucionais, aos riscos relevantes e às necessidades das áreas finalísticas e administrativas.

No iGovTI 2026, a dimensão de governança consolida práticas relacionadas ao modelo de gestão de TIC, à atuação de comitês ou instâncias equivalentes, no monitoramento do desempenho, à participação da alta administração e ao alinhamento entre decisões de TIC, estratégia organizacional, orçamento, riscos e valor público.

A organização **SETD** obteve o **valor 0,8654 no componente Governança de TIC**.

Figura 6 - Resultado do componente Governança de TIC da organização SETD



(Fonte: elaboração própria)

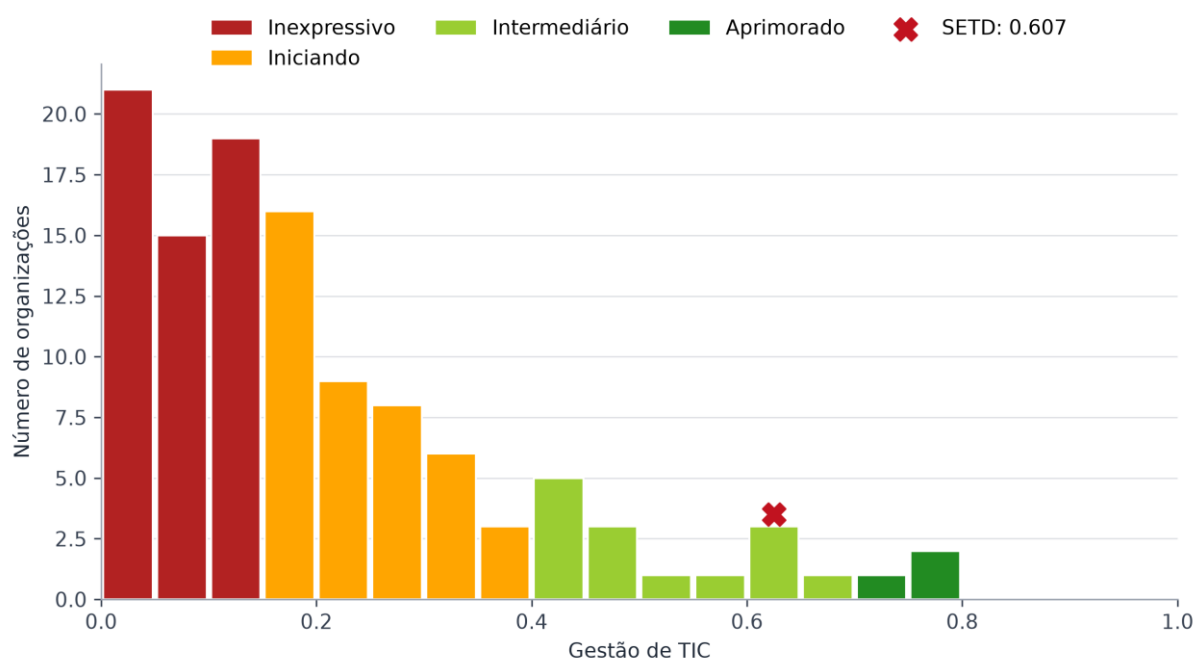
2.2.2. Gestão de TIC

A gestão de TIC avalia a capacidade da organização de planejar, executar, monitorar e aperfeiçoar processos, serviços, controles, recursos e contratações de tecnologia da informação, de forma compatível com suas necessidades institucionais.

No iGovTI 2026, o componente **Gestão de TIC (iGestTI)** consolida seis dimensões operacionais: planejamento de TIC, gestão de serviços de TIC, gestão de riscos de TI e segurança da informação, estrutura de segurança da informação, processos de segurança da informação e gestão de soluções de TIC.

A organização **SETD** obteve o valor **0,6074** no componente **Gestão de TIC**.

Figura 7 - Resultado do componente Gestão de TIC da organização SETD

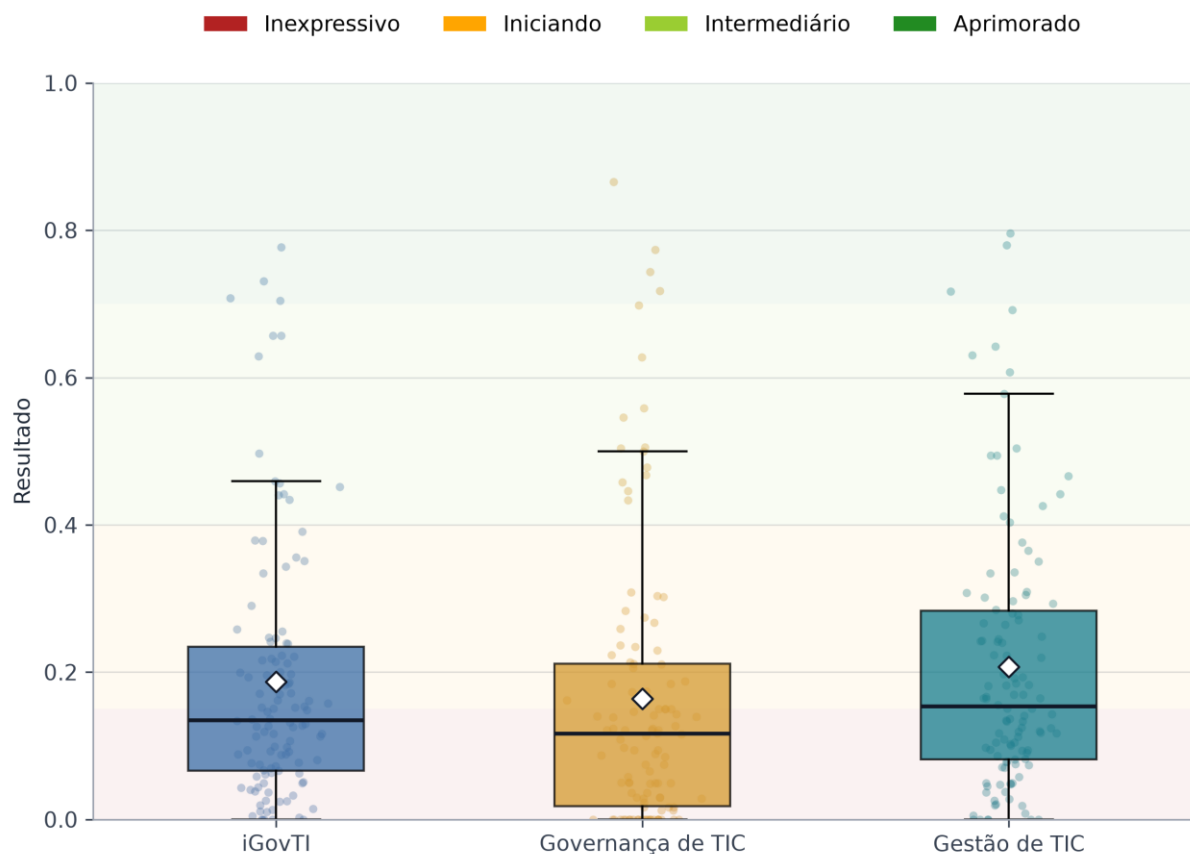


Indicador	Média	1º quartil	Mediana	3º quartil	Organizações com valor >= 0,40	Valor SETD
iGovTI	0,187	0,066	0,135	0,235	14 (12,3%)	0,7306
Governança de TIC	0,164	0,018	0,117	0,211	16 (14,0%)	0,8654
Gestão de TIC	0,208	0,082	0,153	0,283	17 (14,9%)	0,6074

(Fonte: elaboração própria)

A Figura 8 permite comparar a dispersão dos três indicadores. O resultado em Gestão de TIC superou o de Governança de TIC em 76 organizações (66,7%); o movimento inverso ocorreu em 33 (28,9%); e houve igualdade em 5 (4,4%). O padrão indica que, para a maior parte das organizações, as capacidades operacionais de gestão se situaram em patamar superior ao dos mecanismos de direção, monitoramento e controle exercidos pela alta administração. Essa diferença, contudo, não elimina a baixa maturidade da gestão: 97 organizações (85,1%) também obtiveram resultado em Gestão de TIC inferior a 0,40.

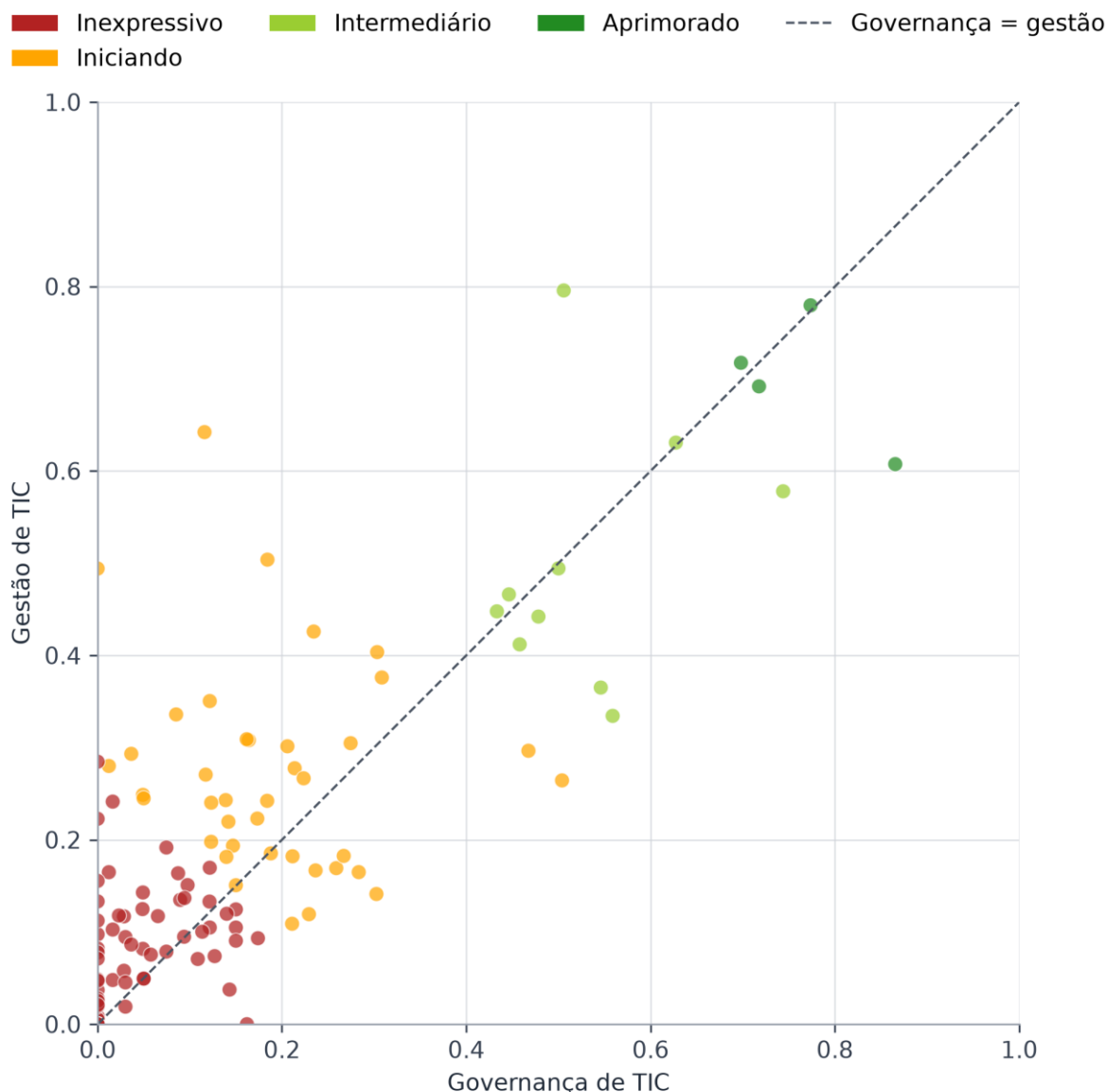
Figura 8 - Distribuição do iGovTI 2026 e dos componentes Governança de TIC e Gestão de TIC



(Fonte: elaboração própria)

A Figura 9 mostra a posição simultânea das organizações nos dois componentes. Pontos abaixo da diagonal representam resultado de gestão superior ao de governança; pontos acima da diagonal representam a situação inversa.

Figura 9 - Relação entre os resultados de governança e gestão de TIC



(Fonte: elaboração própria)

No caso da organização **SETD**, o resultado em Gestão de TIC ficou abaixo do resultado em Governança de TIC. Esse perfil indica oportunidade de fortalecer a transformação das diretrizes de governança em processos, controles, serviços, capacidades operacionais e práticas de gestão de TIC. A leitura deve ser aprofundada à luz das evidências e dos achados correspondentes.

2.4. Dimensões da gestão de TIC

A decomposição da Gestão de TIC revela diferenças relevantes entre as seis dimensões avaliadas. Conforme a Tabela 5, **Planejamento de TIC** apresentou a maior média (0,293) e a maior mediana (0,157). A dimensão com maior média também figurou

como a de maior resultado em 50 organizações (43,9%), considerados os empates. Esse padrão indica que algumas capacidades se encontram mais disseminadas do que outras no conjunto fiscalizado.

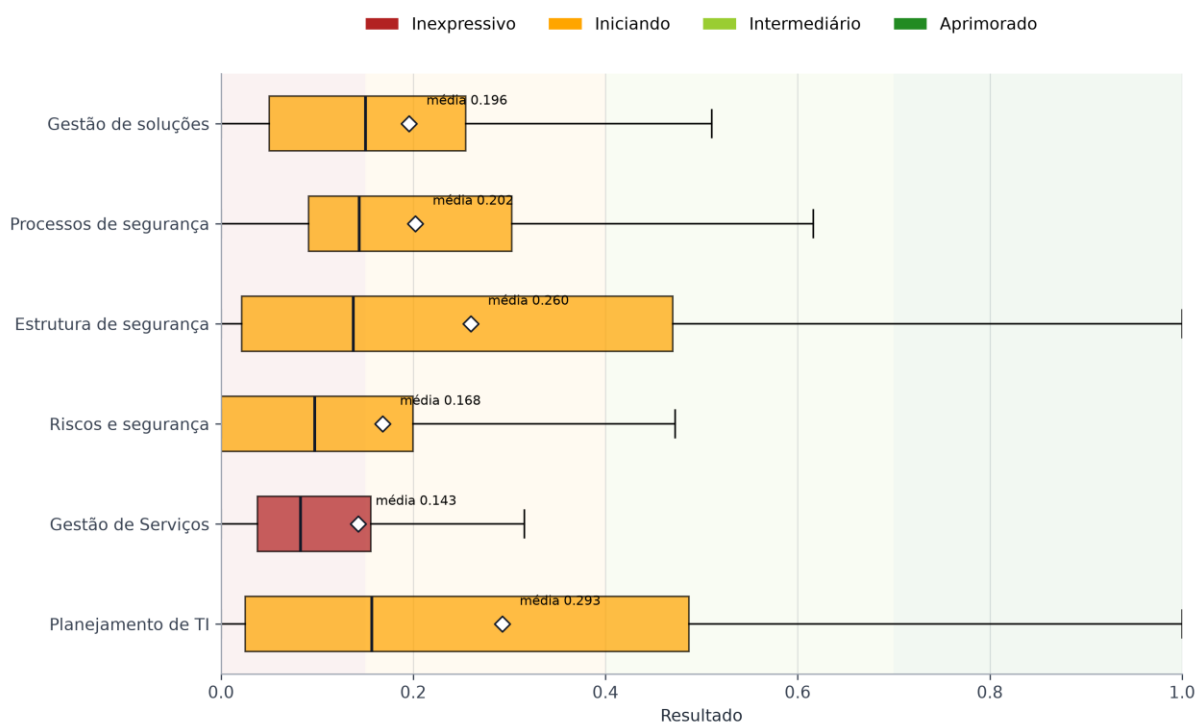
Tabela 5 - Estatísticas descritivas das dimensões de Gestão de TIC

Dimensão	Média	Mediana	Resultados iguais a zero	Organizações com valor inferior a 0,40	Valor SETD
Planejamento de TIC	0,293	0,157	21 (18,4%)	80 (70,2%)	0,9154
Gestão de Serviços de TIC	0,143	0,083	20 (17,5%)	102 (89,5%)	0,3417
Gestão de Riscos de TI e Segurança da Informação	0,168	0,097	32 (28,1%)	97 (85,1%)	0,5693
Estrutura de Segurança da Informação	0,260	0,137	25 (21,9%)	83 (72,8%)	0,7918
Processos de Segurança da Informação	0,202	0,144	10 (8,8%)	95 (83,3%)	0,4757
Gestão de Soluções de TIC	0,196	0,150	26 (22,8%)	101 (88,6%)	0,6265

(Fonte: elaboração própria)

A distribuição completa das seis dimensões é apresentada na Figura 10, incluindo medianas, intervalos interquartis e médias.

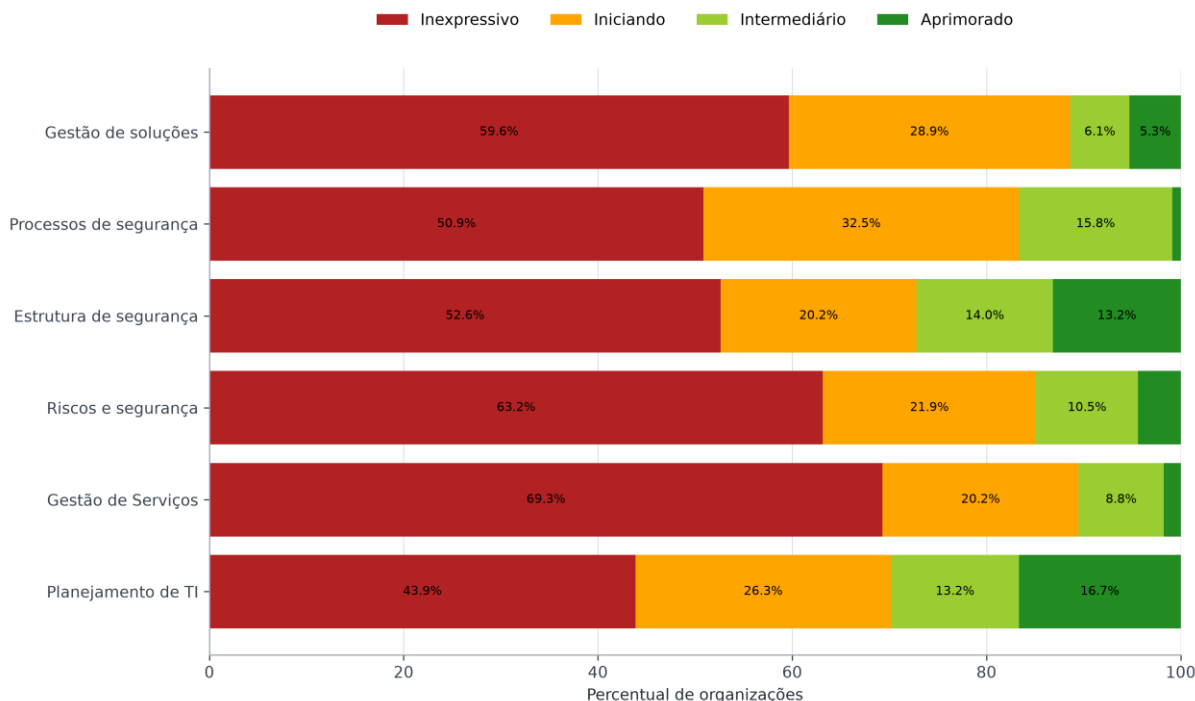
Figura 10 - Distribuição dos resultados das seis dimensões de Gestão de TIC



(Fonte: elaboração própria)

A Figura 11 explicita a composição de cada dimensão por nível de maturidade e permite verificar em quais capacidades se concentram as organizações nos estágios iniciais.

Figura 11 - Distribuição dos níveis de maturidade das organizações nas dimensões de Gestão de TIC



(Fonte: elaboração própria)

As menores médias foram observadas em **Gestão de serviços de TIC** (0,143) e **Riscos de TI e de segurança da informação** (0,168). A primeira registrou valor inferior a 0,40 em 102 organizações (89,5%) e apareceu entre as dimensões de menor resultado de 37 organizações (32,5%), considerados os empates. Para a segunda, esses quantitativos foram, respectivamente, 97 (85,1%) e 39 (34,2%). O quadro indica que a formalização do planejamento, quando existente, frequentemente não é acompanhada, na mesma intensidade, pelas demais capacidades operacionais e de segurança.

A dimensão Estrutura de Segurança da Informação apresentou média de 0,260 e mediana de 0,137. Essa diferença, associada à ampla dispersão observada na Figura 10, evidencia heterogeneidade: um grupo de organizações possui estruturas de segurança mais consolidadas, enquanto parcela expressiva permanece próxima dos níveis inferiores. A dimensão Processos de Segurança da Informação mostrou mediana superior à de Estrutura de Segurança da Informação, mas 83,3% das organizações ainda permaneceram abaixo de 0,40, o que recomenda examinar separadamente a existência da estrutura formal e a execução contínua dos processos de segurança.

2.5. Leitura integrada do resultado individual

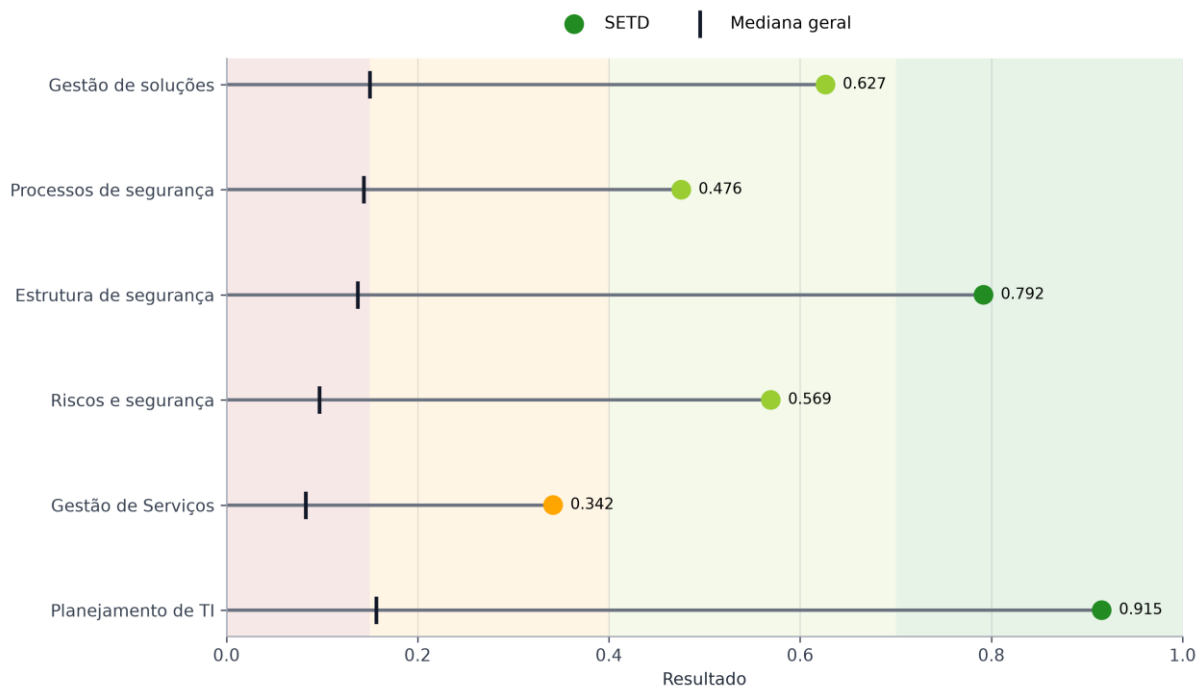
A Figura 12 apresenta o perfil da organização **SETD** nas seis dimensões de gestão e o compara com as medianas observadas nas 114 organizações. A comparação linear da Figura 13 permite identificar com maior precisão a distância entre o resultado individual e a mediana geral em cada dimensão.

Figura 12 - Perfil da organização nas dimensões de Gestão de TIC em comparação com os demais



(Fonte: elaboração própria)

Figura 13 - Comparação do resultado individual e da mediana nas dimensões de Gestão de TIC

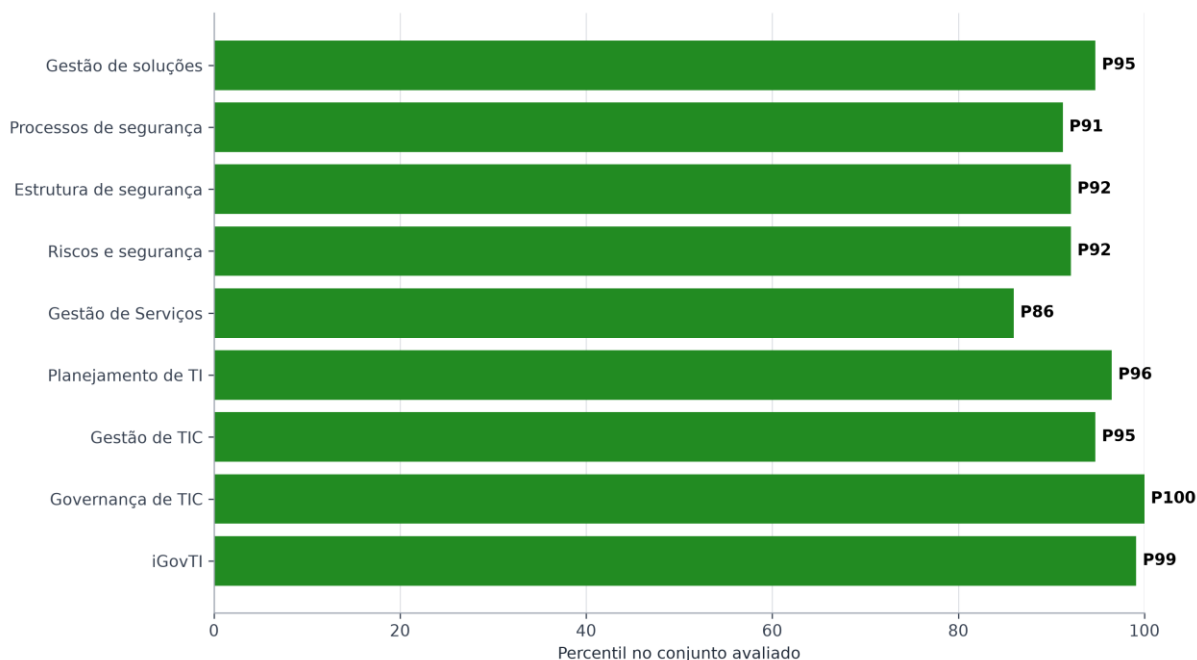


(Fonte: elaboração própria)

A Figura 14 compara a posição da organização **SETD** com as demais organizações avaliadas em cada indicador. A letra “P” indica a posição relativa (percentil) no conjunto: **P50** representa posição próxima ao centro da distribuição; **P90** indica que a organização obteve resultado igual ou superior ao de aproximadamente 90% das organizações avaliadas; e **P20** indica que apenas cerca de 20% das organizações tiveram resultado igual ou inferior. Assim, quanto maior o valor de “P”, melhor é a posição relativa da organização naquele indicador.

Essa comparação deve ser interpretada com cautela. A posição relativa não substitui o valor do índice, o nível de maturidade nem a análise de conformidade realizada nos achados de auditoria. Ela serve apenas para indicar se o resultado da organização ficou relativamente abaixo, próximo ou acima do conjunto avaliado.

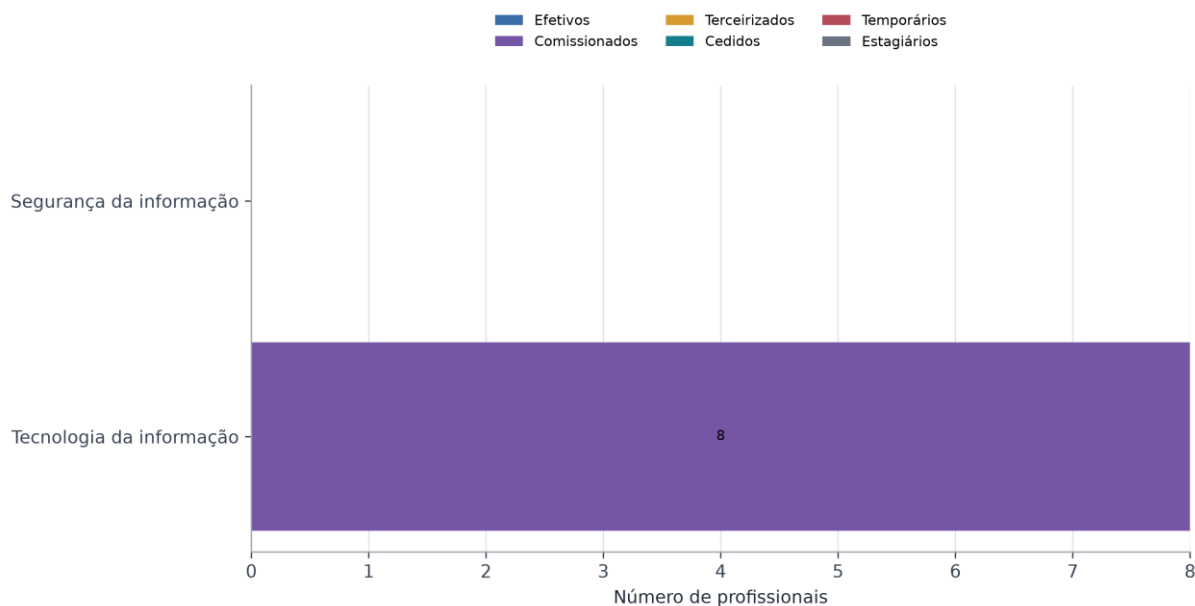
Figura 14 - Comparação da posição relativa da organização SETD nos indicadores avaliados



(Fonte: elaboração própria)

A composição declarada da força de trabalho de TIC e de segurança da informação é apresentada na Figura 15. Os quantitativos não compõem o índice e não medem, isoladamente, suficiência de pessoal; sua avaliação depende do porte, da complexidade, da terceirização, dos serviços mantidos e dos riscos da organização.

Figura 15 - Composição declarada da força de trabalho de TIC e segurança da informação



(Fonte: elaboração própria)

2.5.1. Evolução comparável entre 2023 e 2026

A análise longitudinal foi realizada exclusivamente para organizações com correspondência institucional validada nas bases de 2023 e 2026. Para reduzir os efeitos das alterações promovidas no questionário e na estrutura de cálculo, foram utilizados, em ambos os anos, índices ajustados formados por práticas e agregados comparáveis. Esses valores têm finalidade analítica e não substituem os resultados oficiais divulgados em cada ciclo.

No caso da organização **SETD**, o iGovTI ajustado comparável passou de 0,4092, em 2023, para 0,6543, em 2026, com variação absoluta de +0,2451.

O resultado indica avanço no conjunto harmonizado de práticas avaliadas, embora a organização tenha permanecido no nível **Intermediário** de maturidade.

Tabela 6 - Evolução dos componentes ajustados comparáveis da organização SETD

Indicador	2023	2026	Variação absoluta
iGovTI ajustado comparável	0,4092	0,6543	+0,2451
Governança de TIC	0,5411	0,8367	+0,2956
Gestão de TIC	0,2774	0,4720	+0,1947

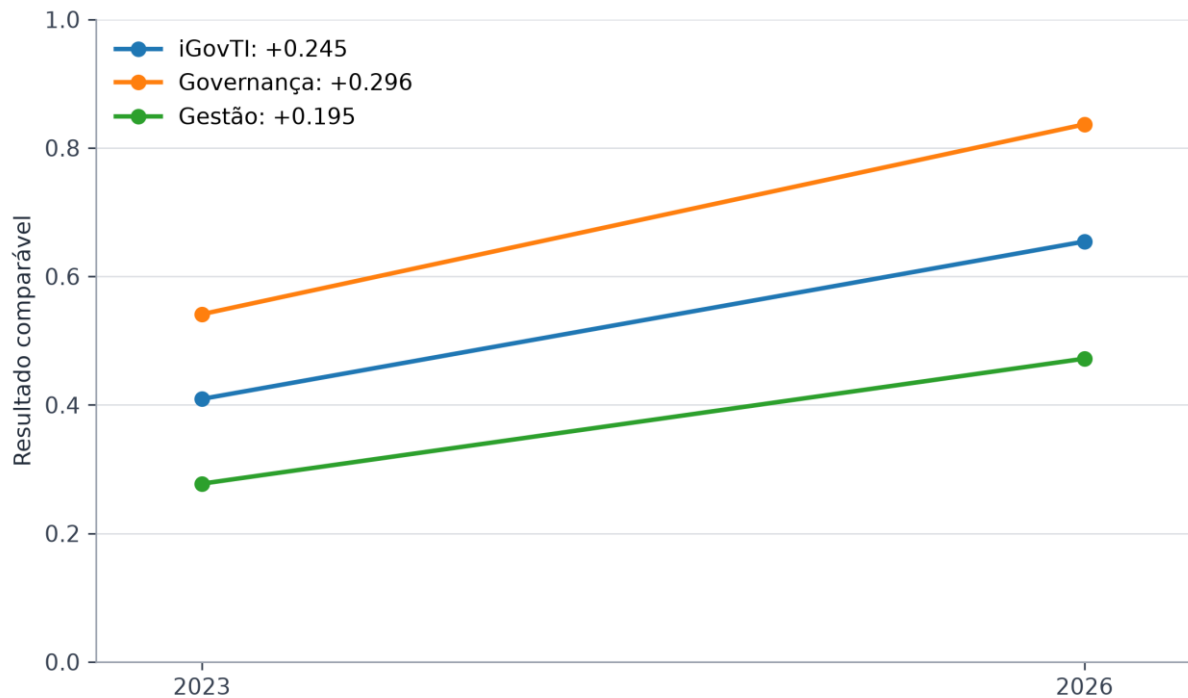
(Fonte: elaboração própria)

Os principais avanços foram observados em Gestão de projetos de TIC (+0.6800); Monitoramento e avaliação de TIC (+0.5416); Planejamento de TIC (+0.5019).

As principais regressões foram observadas em Processos de contratação de TIC (-0.3402); Gestão de níveis de serviço (-0.2917); Gestão de pessoas de TIC (-0.1782).

A Figura 16 apresenta a trajetória dos três indicadores. A variação deve ser interpretada como mudança nas respostas às práticas harmonizadas, e não como comprovação isolada de melhora ou piora da efetividade da TIC. A leitura deve considerar eventuais alterações institucionais, a qualidade das informações declaradas e os achados de auditoria apresentados neste relatório.

Figura 16 - Evolução comparável da organização SETD entre 2023 e 2026



(Fonte: elaboração própria)

A priorização de melhorias não deve buscar apenas a elevação numérica do índice. Recomenda-se concentrar esforços nas capacidades com menor resultado que, simultaneamente, estejam associadas a riscos relevantes, serviços críticos, obrigações normativas e necessidades institucionais da organização **SETD**.

3. Resultados da Auditoria

No âmbito desta fiscalização, foram definidas questões de auditoria para orientar a avaliação da governança e da gestão de TIC. Para fins deste relatório individual preliminar, os possíveis achados decorrem da verificação das Questões 1 a 6.

Tabela 7 - Questões de auditoria com avaliação individual preliminar

Questão	Tema	Síntese do objeto avaliado
Q1	Estrutura de TIC	Existência formal, atribuições e posicionamento organizacional da área, unidade, setor ou função responsável pela TIC.
Q2	Governança e comitê de TIC	Modelo de governança e gestão de TIC, objetivos, indicadores, metas e atuação do comitê ou instância equivalente.
Q3	Planejamento de TIC	Processo de planejamento, plano de TIC vigente, aprovação, alinhamento institucional, integração orçamentária e acompanhamento.
Q4	Capacidade institucional de TIC e segurança da informação	Força de trabalho, perfis, competências, funções, vínculos e capacidade interna para sustentar a TIC e a segurança da informação.
Q5	Gestão de serviços de TIC	Catálogo de serviços, níveis mínimos de serviço, inventário de ativos, gestão de configuração e tratamento de incidentes.
Q6	Contratações de TIC	Fluxo de contratação, papéis, modelos orientativos, aprovação técnica, alinhamento ao planejamento e equipe de planejamento.

(Fonte: elaboração própria)

Não foram identificados achados individuais preliminares relacionados às Questões 2 e 3 para esta organização. Por essa razão, os achados apresentados a seguir preservam a numeração vinculada às questões de auditoria que lhes deram origem.

Os achados de auditoria decorrem da avaliação preliminar das respostas da organização **SETD** ao questionário iGovTI 2026 e da correspondente análise de consistência documental realizada por esta Equipe de Auditoria. O trabalho consistiu no confronto sistemático entre as práticas de governança e gestão autodeclaradas pela organização e as evidências comprobatórias efetivamente encaminhadas, à luz da legislação aplicável e de padrões técnicos de referência internacional.

O presente relatório individual adota uma estrutura analítica de apresentação voltada a conferir clareza, rastreabilidade e utilidade diagnóstica às constatações. Desse modo, cada achado de auditoria está estruturado a partir dos seguintes elementos fundamentais:

- **Critérios:** as referências normativas, legais, regulamentares ou de boas práticas de gestão (como os objetivos do COBIT 2019 e normas da série ABNT NBR ISO/IEC) que estabelecem o padrão esperado de conformidade;

- **Evidências:** a relação das informações e dos documentos anexados pela organização que serviram de suporte factual para as constatações;
- **Situação Encontrada:** a descrição detalhada da realidade operacional e documental identificada no jurisdicionado, destacando-se as fragilidades e lacunas específicas em relação aos critérios adotados;
- **Conclusão da Equipe de Auditoria:** a análise técnica e o juízo profissional formulado a partir da correlação entre a situação factual e as regras de controle estabelecidas no mapa de verificação;
- **Propostas de Encaminhamento:** as recomendações preliminares propostas com o intuito de orientar a organização na correção de fragilidades e no aprimoramento de suas capacidades de governança e gestão de TIC.

Cumprе ressaltar o caráter preliminar das constatações ora apresentadas. A disponibilização deste relatório visa subsidiar a fase de comentários do gestor, permitindo à organização apresentar esclarecimentos adicionais, correções de fato ou novas informações que possam orientar a manifestação final desta Corte de Contas.

Achado 1 – Estrutura de TIC insuficiente para coordenar, gerir e sustentar a tecnologia da informação.

Critérios

- COBIT 2019, APO01.06 - Aprimorar o posicionamento da função de TI: posicionar a função de tecnologia de modo compatível com sua relevância estratégica, responsabilidades e necessidade de interação com a alta administração;
- ABNT NBR ISO/IEC 38500:2025, item 5.6.1 - Governança efetiva de TI: responsabilização clara, estrutura adequada de tomada de decisão e direção organizacional compatível com o uso atual e futuro da tecnologia;
- Portaria SGD/ME nº 778/2019, art. 4º, § 1º - Como referência de boa prática, a área de TIC deve, preferencialmente, estar vinculada à alta administração para apoiá-la na tomada de decisões e no alcance dos objetivos estratégicos.

Evidências

- **E1:** Resposta “c) Centralizada Externa: Os serviços de TI são prestados predominantemente por um órgão, entidade ou estrutura central externa à organização (ex: empresa pública de processamento de dados estadual ou municipal).” ao item 0101 do Questionário, para verificar qual alternativa melhor descreve a formalização e o modelo de operação predominante da Tecnologia da Informação (TI) na organização;
- **E2:** Resposta “e) não há área de TI formalmente instituída ou não há posicionamento hierárquico formal definido para a área de TI” ao item 0102 do Questionário, para verificar como a área de tecnologia da informação está posicionada na estrutura hierárquica da organização.

Situação encontrada

A existência de estrutura formal de TIC é requisito básico para que a organização disponha de unidade, setor ou função institucionalmente reconhecida para planejar, coordenar, gerir, executar, monitorar e controlar o uso da tecnologia da informação. Sob a perspectiva de governança de TIC, essa estruturação envolve três dimensões complementares: formalização da área ou função de TIC, definição de atribuições e competências essenciais e posicionamento organizacional adequado para participar das decisões estratégicas, orçamentárias, contratuais e de gestão de riscos.

Os critérios de boas práticas indicam que a organização deve estabelecer estruturas organizacionais apropriadas, comunicar papéis e responsabilidades de maneira clara, definir

políticas e procedimentos de gestão de TIC e posicionar a função de tecnologia de modo compatível com sua relevância estratégica¹. Esses requisitos convergem com as diretrizes da ABNT NBR ISO/IEC 38500:2025, que orienta sobre a necessidade de responsabilização clara e de estruturas adequadas de tomada de decisão para a governança efetiva de TI², e com a referência de vinculação preferencial da área de TIC à alta administração prevista no art. 4º, § 1º, da Portaria SGD/ME nº 778/2019.

Com base na análise das respostas aos itens 0101, 0102 e 0103 do questionário aplicado e da avaliação das evidências documentais anexadas, não foi demonstrado atendimento integral a esses requisitos de governança. A Equipe de Auditoria identificou as seguintes deficiências na estrutura de TIC da organização:

- **Posicionamento organizacional:** o posicionamento informado não demonstrou compatibilidade suficiente com a relevância e as responsabilidades da função de TIC, em desacordo com o critério de aprimoramento do posicionamento da função de TI (COBIT 2019, APO01.06 e ABNT NBR ISO/IEC 38500:2025, item 5.6.1) e com a referência da Portaria SGD/ME nº 778/2019 (art. 4º, § 1º), o que pode reduzir a capacidade de influência institucional da TIC e comprometer sua participação em decisões estratégicas, orçamentárias, contratuais e de gestão de riscos.

Essa situação ensejou o presente achado e será detalhada na subseção seguinte.

Posicionamento organizacional da área de TIC

O posicionamento organizacional da área de TIC deve ser compatível com suas responsabilidades institucionais e com a dependência da organização em relação à tecnologia da informação. Não se trata de impor modelo único de estrutura, mas de assegurar que a função de TIC tenha capacidade de interação adequada com as instâncias decisórias responsáveis por estratégia, orçamento, contratações, riscos e prestação de serviços.

O COBIT 2019, no objetivo APO01.06, orienta o aprimoramento do posicionamento da função de TI para que a tecnologia seja tratada de modo compatível com sua relevância estratégica e com a necessidade de interação com a alta administração. A ABNT NBR ISO/IEC 38500:2025 reforça a necessidade de estrutura adequada de tomada de decisão para o uso atual e futuro da tecnologia. Como referência complementar de boa prática, o art. 4º, § 1º, da Portaria SGD/ME nº 778/2019 estabelece que a área de TIC deve,

¹ No domínio APO01 do COBIT 2019, a gestão da estrutura organizacional, de papéis, responsabilidades, políticas e posicionamento da função de TI é tratada como condição para que a tecnologia apoie os objetivos de governança e gestão da organização.

² A ABNT NBR ISO/IEC 38500:2025 orienta que a governança efetiva de TI pressupõe responsabilidades claras, estrutura adequada de decisão e direção organizacional compatível com o uso atual e futuro da tecnologia.

preferencialmente, estar vinculada à alta administração, com o intuito de apoiá-la na tomada de decisões e no alcance dos objetivos estratégicos.

Um posicionamento organizacional incompatível com a relevância e as responsabilidades da TIC acarreta o risco de baixa capacidade de influência institucional. Essa fragilidade compromete a participação da área em decisões estratégicas, orçamentárias, contratuais e de gestão de riscos, além de dificultar a priorização de iniciativas e a articulação com as áreas de negócio.

No âmbito da fiscalização, o posicionamento adequado deve ser demonstrado por organograma institucional, regimento interno ou documento equivalente, de modo que seja possível verificar a vinculação da área de TIC e sua compatibilidade com as responsabilidades que lhe foram atribuídas.

Da análise das respostas aos itens 0101 e 0102 e da documentação apresentada, o posicionamento organizacional da área de TIC não se mostrou suficientemente compatível com a relevância e as responsabilidades da função de tecnologia da informação, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- Item 0101: a organização informou possuir área ou modelo de operação de TI, o que levou à análise do seu posicionamento organizacional (E1);
- Item 0102: o posicionamento hierárquico informado pela organização não demonstrou compatibilidade suficiente com a relevância institucional, as responsabilidades e a necessidade de interação da TIC com a alta administração (E2).

Conclusão

As fragilidades identificadas na estrutura de TIC reduzem a segurança de que a organização disponha de condições institucionais suficientes para coordenar, gerir e sustentar a tecnologia da informação de forma alinhada às necessidades institucionais.

Em razão das lacunas descritas, são propostas recomendações preliminares voltadas à adequação dos aspectos da estrutura de TIC efetivamente apontados neste achado, observados os critérios aplicáveis de governança e gestão previstos no COBIT 2019 e na ABNT NBR ISO/IEC 38500:2025, bem como a diretriz de posicionamento organizacional constante do art. 4º, § 1º, da Portaria SGD/ME nº 778/2019. ### Propostas de Encaminhamento

- **Comunicação com Recomendação** para que avalie e ajuste o posicionamento organizacional da área de TIC, atentando-se, minimamente, em assegurar interlocução adequada com a alta administração e participação nas decisões estratégicas, orçamentárias, contratuais e de gestão de riscos relacionadas à tecnologia da informação.



SIGILOSO

Achado 4 – Capacidade institucional insuficiente para sustentar a gestão de TIC e segurança da informação

Critérios

- COBIT 2019, APO01.05 - Estabelecer papéis e responsabilidades: definir, comunicar e manter papéis e responsabilidades relacionados à governança e gestão de TIC;
- COBIT 2019, APO07.01 - Adquirir e manter pessoal adequado e apropriado: assegurar quantidade e perfil de profissionais compatíveis com as necessidades de TIC;
- COBIT 2019, APO07.02 - Identificar pessoal-chave de TI: identificar funções e pessoas críticas para reduzir dependência individual, perda de conhecimento e descontinuidade;
- COBIT 2019, APO07.03 - Manter habilidades e competências do pessoal: identificar, desenvolver e manter competências necessárias à execução das responsabilidades de TIC;
- COBIT 2019, APO07.05 - Planejar e monitorar o uso de recursos humanos de TI e de negócio: planejar, alocar e acompanhar capacidade de pessoal para iniciativas, operações e serviços de TIC;
- ABNT NBR ISO/IEC 27001:2022, cláusulas 5.3 e 7.2: definir responsabilidades e autoridades para segurança da informação e assegurar competências necessárias às funções atribuídas;
- ABNT NBR ISO/IEC 27002:2022, controles 5.2 e 6.3: definir papéis e responsabilidades de segurança da informação e promover conscientização, educação e treinamento em segurança.

Evidências

- **E1:** Ausência de profissionais que atuam regularmente em segurança da informação, conforme informado em resposta ao item 0105;
- **E2:** Resposta negativa ao detalhamento c) do item 2703 do Questionário, para verificar se definiu-se, de maneira documentada, um quantitativo necessário de pessoal da área de tecnologia da informação e segurança da informação;
- **E3:** Resposta negativa ao subitem b) do item 2708 do Questionário, para verificar se a organização possui em sua estrutura cargos ou funções formalmente atribuídas à área de tecnologia da informação;

- **E4:** Resposta negativa ao subitem d) do item 2708 do Questionário, para verificar se a organização possui em sua estrutura cargos ou funções formalmente atribuídas à área de segurança da informação;
- **E5:** Resposta negativa ao detalhamento b) do item 2704 do Questionário, para verificar se os gestores são selecionados com base em perfil profissional previamente definido e documentado, e compatível com o cargo ou função para o qual tenha sido indicado;
- **E6:** Resposta negativa ao detalhamento b) do item 2705 do Questionário, para verificar se as lacunas de competências de liderança e gestão necessárias para a atuação dos gestores da organização são identificadas e documentadas;
- **E7:** Resposta negativa ao detalhamento c) do item 2705 do Questionário, para verificar se as lacunas de competências técnicas da área de tecnologia da informação necessárias para a atuação dos colaboradores da organização são identificadas e documentadas;
- **E8:** Resposta negativa ao detalhamento d) do item 2705 do Questionário, para verificar se as lacunas de competências técnicas da área de segurança da informação necessárias para a atuação dos colaboradores da organização são identificadas e documentadas;
- **E9:** Resposta negativa ao detalhamento a) do item 2706 do Questionário, para verificar se a organização elabora plano de capacitação (plano de treinamento) visando o tratamento das lacunas de competência identificadas.

Situação encontrada

A capacidade institucional de TIC e segurança da informação pressupõe dispor de recursos humanos, competências, perfis profissionais, funções e vínculos contratuais adequados para planejar, coordenar, gerir, proteger, contratar, fiscalizar e sustentar o ambiente tecnológico. Sob a perspectiva de controle e governança, a estruturação formal de uma unidade de tecnologia deve ser acompanhada de capacidade técnica compatível para exercer a supervisão de suas atribuições estratégicas.

Os critérios de boas práticas indicam que a organização deve formalizar a designação de papéis e responsabilidades, assegurar o dimensionamento apropriado do quadro de pessoal, mapear funções críticas, capacitar periodicamente a equipe e supervisionar de forma estrita a atuação de prestadores de serviços externos³.

Com base na análise das respostas aos itens 0101, 0105, 2701, 2702, 2703, 2704, 2705, 2706, 2708, 2801 e 2804 do questionário aplicado e da avaliação das evidências

³ Os critérios de capacidade institucional de TIC e segurança da informação concentram-se em pessoal adequado, competências, papéis, responsabilidades, retenção de conhecimento e supervisão de terceiros.

documentais anexadas, não foi demonstrada capacidade institucional suficiente para sustentar a gestão de TIC e segurança da informação. A Equipe de Auditoria identificou fragilidades nos seguintes aspectos:

- **Força de trabalho dedicada:** a ausência de força de trabalho dedicada não demonstra aderência aos critérios de pessoal adequado, planejamento de recursos humanos e competências de segurança da informação (COBIT 2019, APO07.01/APO07.05 e ABNT NBR ISO/IEC 27001:2022, cláusulas 5.3 e 7.2), podendo comprometer a execução rotineira das atividades de planejamento, governança e sustentação operacional.
- **Dimensionamento de pessoal:** a ausência de definição de parâmetros de pessoal não demonstra aderência aos critérios de planejamento de recursos humanos (COBIT 2019, APO07.01), elevando o risco de subdimensionamento ou má alocação da equipe técnica.
- **Cargos e carreiras específicas:** a ausência de cargos, funções ou perfis técnicos estruturados não demonstra aderência às boas práticas de atração e retenção de pessoal (COBIT 2019, APO07.01), podendo reduzir a responsabilização e a continuidade da gestão tecnológica.
- **Perfis profissionais:** a ausência ou inobservância de perfis profissionais mínimos para a escolha de gestores e técnicos não demonstra aderência às diretrizes de manutenção de competências (COBIT 2019, APO07.01/APO07.03 e ISO/IEC 27002:2022, 5.2/6.3), reduzindo a segurança de que os responsáveis possuam qualificação compatível com as funções exercidas.
- **Lacunas de competência:** a ausência de identificação ou tratamento de lacunas de treinamento não demonstra aderência às recomendações de capacitação técnica (COBIT 2019, APO07.03 e ISO/IEC 27002:2022, 6.3), podendo fragilizar a operação de segurança e o gerenciamento de ativos de TIC.

Essas situações ensejaram o presente achado e serão detalhadas nas subseções seguintes.

Força de trabalho dedicada à TIC ou à segurança da informação

A organização deve dispor de força de trabalho dedicada à TIC e à segurança da informação, compatível com sua estrutura, porte, serviços prestados, sistemas mantidos, contratações e riscos relevantes.

O COBIT 2019, APO07.01 e APO07.05, orienta a manutenção de pessoal adequado e o planejamento e monitoramento da capacidade de recursos humanos. A ABNT NBR ISO/IEC 27001:2022, cláusulas 5.3 e 7.2, exige responsabilidades definidas e competências necessárias às funções atribuídas em segurança da informação.

Da análise das respostas ao item 0105 e da documentação apresentada, verificou-se que a existência de força de trabalho dedicada à TIC ou à segurança da informação compatível com as responsabilidades da organização não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- Não foi identificada força de trabalho dedicada à segurança da informação no quantitativo informado pela organização (E1).

A inexistência ou insuficiência de profissionais dedicados, em quantitativo compatível com a complexidade do ambiente tecnológico, reduz a segurança quanto à capacidade da organização de executar rotinas essenciais de planejamento, gestão, segurança da informação, contratação, fiscalização contratual e sustentação das operações de TIC.

Quantitativo necessário de pessoal de TIC e segurança da informação

A definição do quantitativo necessário de pessoal permite avaliar se a força de trabalho disponível é compatível com as demandas, riscos e responsabilidades da organização.

O COBIT 2019, APO07.01 e APO07.05, exige que a organização assegure quantidade e perfil de profissionais compatíveis com as necessidades de TIC e planeje a alocação de recursos humanos para iniciativas, operações e serviços.

Da análise das respostas ao item 2703 e da documentação apresentada, verificou-se que a definição do quantitativo necessário de pessoal de TIC e segurança da informação com base em critério ou procedimento técnico não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem c) do item 2703, não houve declaração afirmativa quanto à prática avaliada: definiu-se, de maneira documentada, um quantitativo necessário de pessoal da área de tecnologia da informação e segurança da informação (E2).

A ausência de dimensionamento técnico do quadro de pessoal reduz a disponibilidade de bases objetivas para subsidiar decisões sobre contratações, provimentos, planos de capacitação ou eventual compartilhamento de estruturas com outras organizações.

Cargos, funções, perfis ou ocupações específicas de TIC e segurança da informação

Cargos, funções, gratificações, perfis ou ocupações específicas de TIC e segurança da informação ajudam a estruturar responsabilidades, atrair profissionais, definir requisitos mínimos e reduzir improvisação na alocação de pessoas.

O COBIT 2019, APO01.05, APO07.01 e APO07.02, orienta a definição de papéis e responsabilidades, a manutenção de pessoal adequado e a identificação de funções críticas de TI.

Da análise das respostas ao item 2708 e da documentação apresentada, verificou-se que a existência de cargos, funções, gratificações, perfis ou ocupações específicas de TIC e segurança da informação não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem b) do item 2708, não houve declaração afirmativa quanto à prática avaliada: possui em sua estrutura cargos ou funções formalmente atribuídas à área de tecnologia da informação (E3);
- No subitem d) do item 2708, não houve declaração afirmativa quanto à prática avaliada: possui em sua estrutura cargos ou funções formalmente atribuídas à área de segurança da informação (E4).

A ausência de cargos, funções, gratificações, perfis ou ocupações específicas de TIC e segurança da informação pode reduzir a capacidade de atração, responsabilização e retenção de profissionais com perfil compatível com as necessidades da área.

Perfis profissionais de TIC e segurança da informação

A definição de perfis profissionais mínimos para gestores e colaboradores de TIC e segurança da informação é necessária para que as pessoas designadas possuam competências compatíveis com suas responsabilidades.

O COBIT 2019, APO01.05 e APO07.03, orienta a definição de papéis, responsabilidades e competências necessárias. A ABNT NBR ISO/IEC 27001:2022 também exige competências adequadas às funções atribuídas em segurança da informação.

Da análise das respostas aos itens 2701, 2702 e 2704 e da documentação apresentada, verificou-se que a definição ou utilização de perfis profissionais mínimos para gestores e colaboradores de TIC e segurança da informação não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem b) do item 2704, não houve declaração afirmativa quanto à prática avaliada: os gestores são selecionados com base em perfil profissional previamente definido e documentado, e compatível com o cargo ou função para o qual tenha sido indicado (E5).

A ausência de perfis profissionais mínimos ou de sua utilização como referência para designação de gestores e técnicos eleva o risco de alocação de colaboradores sem qualificação compatível com atividades críticas de tecnologia da informação e segurança da informação.

Identificação e tratamento de lacunas de competências

A organização deve identificar periodicamente lacunas de competências dos gestores e colaboradores de TIC e segurança da informação e definir medidas de tratamento, como capacitação, realocação, provimento, apoio especializado, compartilhamento de estrutura ou contratação com transferência de conhecimento.

O COBIT 2019, APO07.03, orienta a manutenção de habilidades e competências necessárias à execução das responsabilidades de TIC. A ABNT NBR ISO/IEC 27002:2022, controles 5.2 e 6.3, reforça a definição de responsabilidades e a promoção de conscientização, educação e treinamento em segurança.

Da análise das respostas aos itens 2705 e 2706 e da documentação apresentada, verificou-se que a identificação ou o tratamento de lacunas de competências dos gestores e colaboradores de TIC e segurança da informação não se mostrou suficientemente demonstrado, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem b) do item 2705, não houve declaração afirmativa quanto à prática avaliada: as lacunas de competências de liderança e gestão necessárias para a atuação dos gestores da organização são identificadas e documentadas (E6);
- No subitem c) do item 2705, não houve declaração afirmativa quanto à prática avaliada: as lacunas de competências técnicas da área de tecnologia da informação necessárias para a atuação dos colaboradores da organização são identificadas e documentadas (E7);
- No subitem d) do item 2705, não houve declaração afirmativa quanto à prática avaliada: as lacunas de competências técnicas da área de segurança da informação necessárias para a atuação dos colaboradores da organização são identificadas e documentadas (E8);
- No subitem a) do item 2706, não houve declaração afirmativa quanto à prática avaliada: elabora plano de capacitação (plano de treinamento) visando o tratamento das lacunas de competência identificadas (E9).

A ausência de diagnóstico regular sobre competências internas e de medidas para tratamento de lacunas dificulta o acompanhamento da evolução tecnológica e pode reduzir a capacidade da equipe técnica de administrar sistemas, infraestrutura e controles de segurança da informação de forma compatível com os riscos existentes.

Conclusão

As fragilidades identificadas na capacidade institucional de TIC e segurança da informação reduzem a segurança de que a organização disponha, conforme aplicável ao caso concreto, de pessoal, competências, papéis, perfis profissionais e mecanismos de

supervisão suficientes para sustentar a gestão, a proteção, as contratações, a fiscalização e a continuidade dos serviços tecnológicos.

Em razão das lacunas descritas, são propostas recomendações preliminares voltadas à adequação dos aspectos de capacidade institucional de TIC e segurança da informação efetivamente apontados neste achado, observados os critérios aplicáveis indicados nas seções anteriores.

Propostas de Encaminhamento

- **Comunicação com Recomendação** para que avalie a força de trabalho dedicada à TIC e à segurança da informação e adote medidas proporcionais para assegurar capacidade mínima de planejamento, gestão, proteção, contratação, fiscalização e sustentação dos serviços e ativos de TIC;
- **Comunicação com Recomendação** para que estime e mantenha atualizado o quantitativo necessário de pessoal de TIC e segurança da informação, considerando o porte e a complexidade da organização, os serviços críticos, os sistemas mantidos, as contratações vigentes e os riscos relevantes;
- **Comunicação com Recomendação** para que avalie a necessidade de instituir cargos, funções, gratificações, perfis ou ocupações específicas de TIC e segurança da informação e adote a solução compatível com as necessidades institucionais e a capacidade administrativa da organização;
- **Comunicação com Recomendação** para que defina perfis profissionais mínimos para gestores e colaboradores de TIC e segurança da informação, atentando-se, minimamente, em estabelecer conhecimentos, habilidades, experiência e responsabilidades requeridos e utilizar esses perfis na seleção e designação dos responsáveis;
- **Comunicação com Recomendação** para que realize diagnóstico periódico das lacunas de competências dos gestores e colaboradores de TIC e segurança da informação e estabeleça plano de tratamento, contemplando, conforme a necessidade, capacitação, realocação, provimento, apoio especializado, compartilhamento de estrutura ou contratação com transferência de conhecimento.

Achado 5 – Gestão de serviços de TIC insuficiente para assegurar controle sobre serviços, ativos e incidentes

Critérios

- ITIL 4, prática de gerenciamento do catálogo de serviços: manter fonte única de informações consistentes sobre serviços e ofertas de serviço, disponível para usuários e equipes de suporte;
- COBIT 2019, APO09.02 - Catalogar serviços facilitados por TI: definir, manter e comunicar catálogo de serviços, incluindo serviços prestados, características, requisitos e níveis de serviço esperados;
- ITIL 4, prática de gerenciamento de nível de serviço: definir, acordar, monitorar, avaliar e reportar metas e níveis de serviço alinhados às necessidades das áreas usuárias;
- ITIL 4, prática de gerenciamento de incidentes: minimizar o impacto negativo dos incidentes por meio da restauração tempestiva da operação normal dos serviços e do registro rastreável do tratamento realizado;
- COBIT 2019, DSS02.02, DSS02.04 e DSS02.07 - Requisições de serviço e incidentes gerenciados: registrar, classificar, priorizar, investigar, diagnosticar, resolver, acompanhar e reportar incidentes e requisições de serviço.

Evidências

- **E1:** A organização declarou “Sim” no subitem a) do item 2201, mas a evidência encaminhada foi considerada insuficiente para comprovar que o catálogo contém as metas definidas para cada serviço (p. ex.: prazos de entrega, horários de serviço e de suporte, bem como pontos de contato para solicitação do serviço, envio de sugestões, esclarecimento de dúvidas e reporte de incidentes);
 - Justificativa da avaliação: A avaliação realizada indica que não há catálogo de serviços de TI com as metas operacionais exigidas, como prazos, horários de suporte ou pontos de contato. O documento limita-se a um cronograma de execução de ações de cooperação, sem definição de níveis de serviço voltados aos usuários. Falta a formalização de um catálogo que especifique as metas e condições de entrega dos serviços;
- **E2:** Resposta negativa ao detalhamento b) do item 2201 do Questionário, para verificar se o catálogo está atualizado e as informações que nele constam são compatíveis com os Acordos de Níveis de Serviço (ANS) estabelecidos pela área de tecnologia da informação e as áreas de negócio da organização;

- **E3:** A organização declarou “Sim” no subitem c) do item 2201, mas a evidência encaminhada foi considerada insuficiente para comprovar que o catálogo é de fácil acesso e está amplamente disponível a seus usuários e às equipes de suporte;
 - Justificativa da avaliação: A avaliação realizada indica que não é possível constatar a acessibilidade de um catálogo de serviços, visto que tal instrumento não foi apresentado. A ausência de um catálogo de serviços estruturado inviabiliza a verificação da sua disponibilidade aos usuários. Inexiste evidência de portal, sistema ou documento de acesso amplo aos usuários e às equipes de suporte;
- **E4:** Resposta negativa ao detalhamento d) do item 2201 do Questionário, para verificar se são formalizados ANS contendo metas de nível de serviço acordadas com representantes das áreas de negócio clientes;
- **E5:** A organização declarou “Sim” no subitem e) do item 2201, mas a evidência encaminhada foi considerada insuficiente para comprovar que a área de gestão de tecnologia da informação monitora continuamente o alcance dos níveis de serviço estabelecidos nos ANS;
 - Justificativa da avaliação: A avaliação realizada indica que não há monitoramento contínuo de níveis de serviço (ANS) conforme exigido. As cláusulas do acordo referem-se ao acompanhamento administrativo das ações da parceria, sem contemplar indicadores de desempenho ou metas de disponibilidade de serviços de TI. Falta a comprovação de monitoramento sistemático voltado aos serviços prestados aos usuários;
- **E6:** A organização declarou “Sim” no subitem a) do item 2204, mas a evidência encaminhada foi considerada insuficiente para comprovar que definiu regras para a priorização e o escalamento de incidentes;
 - Justificativa da avaliação: Não há, no Acordo de Cooperação Técnica, regras ou critérios definidos para a priorização e escalamento de incidentes. O documento limita-se a estabelecer responsabilidades genéricas pela coordenação da parceria e suporte técnico. A evidência é insuficiente, pois faltam matrizes de impacto, severidade ou fluxos operacionais de escalonamento;
- **E7:** A organização declarou “Sim” no subitem d) do item 2204, mas a evidência encaminhada foi considerada insuficiente para comprovar que o(s) processo(s) de gestão de incidentes está(ão) formalizado(s) (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades);

- Justificativa da avaliação: O Acordo de Cooperação Técnica não constitui a formalização requerida para o processo de gestão de incidentes. Não foi apresentada norma interna, guia ou procedimento específico que defina etapas, papéis e responsabilidades para o tratamento de incidentes. A evidência é insuficiente por não apresentar o instrumento normativo do processo;
- **E8:** A organização declarou “Sim” no subitem e) do item 2204, mas a evidência encaminhada foi considerada insuficiente para comprovar que definiu procedimentos e responsabilidades quanto à notificação e ao tratamento das notificações de incidentes de segurança da informação, bem como quanto à adoção de ações emergenciais, diretrizes para escalamento e comunicação interna e externa;
 - Justificativa da avaliação: O documento não define procedimentos ou responsabilidades quanto à notificação e tratamento de incidentes de segurança da informação. Embora existam cláusulas sobre sigilo e LGPD, não há diretrizes para ações emergenciais, escalamento ou comunicação específica para eventos de segurança. A evidência é insuficiente devido à ausência de fluxo ou norma de tratamento de incidentes de segurança.

Situação encontrada

A gestão de serviços de TIC organiza a forma como as soluções e o suporte tecnológico são entregues aos usuários e às áreas demandantes do órgão. Catálogo de serviços, Acordos de Nível de Serviço (ANS), inventário de ativos, gestão de configuração e gestão de incidentes constituem práticas básicas e integradas necessárias para assegurar a transparência operacional, continuidade do negócio, governabilidade financeira, controle de ativos e qualidade de suporte técnico.

Os critérios de boas práticas baseados na ITIL 4 e no COBIT 2019 indicam que a organização deve manter fonte unificada e consistente de informações sobre seu catálogo, estabelecer metas mensuráveis de atendimento, administrar ativamente o ciclo de vida dos ativos tecnológicos, rastrear os relacionamentos lógicos de configuração e registrar de forma sistemática e auditável todas as ocorrências operacionais e incidentes de segurança⁴.

Com base na análise das respostas aos itens 2201, 2203, 2204 e 2504 do questionário aplicado e da avaliação das evidências documentais anexadas, não foi demonstrada adoção suficiente dessas práticas mínimas. A Equipe de Auditoria identificou fragilidades nos seguintes aspectos:

⁴ As práticas de gestão de serviços de TIC adotadas como critério baseiam-se em ITIL 4 e COBIT 2019 e abrangem catálogo, níveis de serviço, ativos, configuração e incidentes.

- **Catálogo de serviços de TIC:** a fragilidade ou ausência do catálogo não demonstra aderência à ITIL 4 e ao COBIT 2019 (APO09.02), podendo resultar em prestação reativa, sem transparência ou definição clara das entregas técnicas disponíveis.
- **Níveis mínimos de serviço:** a ausência de parâmetros ou acompanhamento não demonstra aderência aos critérios de catálogo e gerenciamento de nível de serviço (ITIL 4 e COBIT 2019, APO09.02), dificultando a avaliação objetiva da qualidade e tempestividade dos serviços prestados.
- **Gestão de incidentes de TIC:** a inexecução ou informalidade no processo de atendimento não demonstra aderência à ITIL 4 e ao COBIT 2019 (DSS02.02, DSS02.04 e DSS02.07), dificultando o tratamento padronizado, tempestivo e rastreável de falhas tecnológicas.

Essas situações ensejaram o presente achado e serão detalhadas nas subseções seguintes.

Catálogo de serviços de TIC

O catálogo de serviços de TIC deve constituir fonte única de informações consistentes sobre os serviços prestados, acessível aos usuários e às áreas demandantes. Deve conter informações mínimas sobre os serviços efetivamente prestados, suas características, requisitos, canais de atendimento e níveis esperados de serviço.

A ITIL 4, na prática de gerenciamento do catálogo de serviços, orienta a manutenção de informações consistentes e disponíveis sobre serviços e ofertas de serviço. O COBIT 2019, APO09.02, exige a definição, manutenção e comunicação do catálogo de serviços facilitados por TI.

Da análise das respostas ao item 2201 e da documentação apresentada, verificou-se que a existência de catálogo de serviços de TIC atualizado, acessível aos usuários e com informações mínimas sobre os serviços prestados não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2201, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que o catálogo contém as metas definidas para cada serviço (p. ex.: prazos de entrega, horários de serviço e de suporte, bem como pontos de contato para solicitação do serviço, envio de sugestões, esclarecimento de dúvidas e reporte de incidentes) (E1);
- No subitem b) do item 2201, não houve declaração afirmativa quanto à prática avaliada: o catálogo está atualizado e as informações que nele constam são compatíveis com os Acordos de Níveis de Serviço (ANS) estabelecidos pela área de tecnologia da informação e as áreas de negócio da organização (E2);

- No subitem c) do item 2201, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que o catálogo é de fácil acesso e está amplamente disponível a seus usuários e às equipes de suporte (E3).

A inexistência, desatualização ou falta de divulgação do catálogo de serviços dificulta que os usuários conheçam o portfólio de entregas e os canais corretos de atendimento, elevando o risco de prestação de suporte de forma reativa, informal ou pouco transparente.

Níveis de serviço e metas de atendimento

A definição de Acordos de Níveis de Serviço, metas mínimas ou parâmetros equivalentes permite pactuar expectativas, medir desempenho e avaliar a qualidade dos principais serviços de TIC.

A ITIL 4, na prática de gerenciamento de nível de serviço, orienta a definição, monitoramento, avaliação e reporte de metas e níveis de serviço alinhados às necessidades das áreas usuárias. O COBIT 2019, APO09.02, também relaciona o catálogo à comunicação de requisitos e níveis de serviço esperados.

Da análise das respostas ao item 2201 e da documentação apresentada, verificou-se que a definição ou o monitoramento de níveis mínimos de serviço, metas ou parâmetros equivalentes para os serviços de TIC relevantes não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem d) do item 2201, não houve declaração afirmativa quanto à prática avaliada: são formalizados ANS contendo metas de nível de serviço acordadas com representantes das áreas de negócio clientes (E4);
- No subitem e) do item 2201, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que a área de gestão de tecnologia da informação monitora continuamente o alcance dos níveis de serviço estabelecidos nos ANS (E5).

A ausência de níveis mínimos de serviço, metas estruturadas ou parâmetros equivalentes reduz a disponibilidade de bases objetivas para monitorar e avaliar a qualidade, o tempo de resposta e a eficiência dos serviços prestados.

Gestão de incidentes de TIC

A gestão de incidentes de TIC deve definir papéis, responsabilidades, critérios de priorização, escalamento, tratamento, registro sistemático, histórico das ocorrências e análise posterior de incidentes relevantes ou recorrentes.

A ITIL 4, na prática de gerenciamento de incidentes, orienta minimizar impactos negativos por meio da restauração tempestiva da operação normal e do registro rastreável do tratamento realizado. O COBIT 2019, DSS02.02, DSS02.04 e DSS02.07, exige registrar,

classificar, priorizar, investigar, diagnosticar, resolver, acompanhar e reportar incidentes e requisições de serviço.

Da análise das respostas ao item 2204 e da documentação apresentada, verificou-se que a existência de processo mínimo de gestão de incidentes de TIC com papéis, critérios de priorização, escalamento, tratamento, registro sistemático e análise posterior de ocorrências relevantes ou recorrentes não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2204, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que definiu regras para a priorização e o escalamento de incidentes (E6);
- No subitem d) do item 2204, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que o(s) processo(s) de gestão de incidentes está(ão) formalizado(s) (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades) (E7);
- No subitem e) do item 2204, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que definiu procedimentos e responsabilidades quanto à notificação e ao tratamento das notificações de incidentes de segurança da informação, bem como quanto à adoção de ações emergenciais, diretrizes para escalamento e comunicação interna e externa (E8).

O tratamento assistemático ou sem registro centralizado das falhas tecnológicas dificulta o acompanhamento do histórico de incidentes, a identificação de causas raiz e a redução do período de indisponibilidade dos sistemas corporativos.

Conclusão

As fragilidades identificadas na gestão de serviços de TIC reduzem a segurança de que a organização disponha, conforme aplicável ao caso concreto, de práticas suficientes para assegurar eficiência, continuidade, rastreabilidade, qualidade dos serviços prestados e controle sobre ativos, configurações e incidentes.

Em razão das lacunas descritas, são propostas recomendações preliminares voltadas à estruturação e à adequação das práticas de gestão de serviços de TIC efetivamente apontadas neste achado, observados os critérios aplicáveis indicados nas seções anteriores.

Propostas de Encaminhamento

- **Comunicação com Recomendação** para que institua e mantenha atualizado catálogo de serviços de TIC, atentando-se, minimamente, em identificar os serviços

efetivamente prestados, seus responsáveis, usuários, condições de acesso e informações necessárias ao atendimento das áreas demandantes;

- **Comunicação com Recomendação** para que defina, pactue e monitore níveis mínimos de serviço ou metas de atendimento para os serviços de TIC mais relevantes, estabelecendo indicadores, responsáveis, periodicidade de medição e forma de comunicação dos resultados;
- **Comunicação com Recomendação** para que formalize e execute processo de gestão de incidentes de TIC, atentando-se, minimamente, em definir papéis, responsabilidades, critérios de priorização e escalamento, tratamento de incidentes de serviços e de segurança da informação, registro sistemático e rastreável das ocorrências e análise posterior dos incidentes relevantes ou recorrentes.

Achado 6 – Fragilidades na governança técnica da fase preparatória das contratações de TIC

Critérios

- Art. 11, parágrafo único, da Lei 14.133/2021: responsabilidade da alta administração pela governança das contratações, com processos, estruturas, gestão de riscos e controles internos;
- Art. 19, inciso IV, da Lei 14.133/2021: instituição de modelos de minutas de editais, termos de referência, contratos padronizados e demais documentos;
- COBIT 2019, BAI02.04 - Obter aprovação dos requisitos da solução: obter aprovação formal dos requisitos funcionais, técnicos, de segurança e de conformidade antes de prosseguir com a solução;
- COBIT 2019, APO01.05 - Estabelecer papéis e responsabilidades: definir e comunicar papéis e responsabilidades relacionados à informação e à tecnologia;
- COBIT 2019, APO01.09 - Definir e comunicar políticas e procedimentos: manter políticas, procedimentos e orientações para direcionar processos de gestão de TIC;
- Instrução Normativa SGD/ME nº 94, de 23 de dezembro de 2022, art. 1º, § 1º: como referência de boa prática, a aplicação de ritos formais de contratação de TIC pode ser facultada para contratações diretas por dispensa em razão do valor (inciso II do art. 75 da Lei nº 14.133/2021), indicando a possibilidade de fluxos simplificados para aquisições de baixa complexidade ou valor.

Evidências

- **E1:** A organização declarou “Sim” no subitem a) do item 2801, mas a evidência encaminhada foi considerada insuficiente para comprovar que o processo de trabalho para o planejamento das contratações de TI contempla as etapas, as responsabilidades dos atores envolvidos e os artefatos resultantes de cada etapa;
 - Justificativa da avaliação: A avaliação realizada indica não conformidade, uma vez que a norma apresentada foca majoritariamente na fase de gestão contratual. O PEDTIC aborda o planejamento estratégico, mas não detalha as etapas, responsabilidades ou artefatos específicos do rito de planejamento de contratações de TI. A evidência é insuficiente para sustentar a afirmação. A lacuna relevante é a ausência de um fluxo de planejamento de contratação detalhado com papéis e entregáveis por etapa;
- **E2:** Resposta negativa ao detalhamento c) do item 2801 do Questionário, para verificar se o processo de trabalho para a seleção de fornecedores contempla as

etapas, as responsabilidades dos atores envolvidos e os artefatos resultantes de cada etapa;

- **E3:** A organização declarou “Sim” no subitem d) do item 2801, mas a evidência encaminhada foi considerada insuficiente para comprovar que são disponibilizados artefatos padronizados para a fase de seleção de fornecedores, como minutas, checklists, modelos de edital, pareceres, critérios de julgamento ou documentos equivalentes;
 - Justificativa da avaliação: A avaliação realizada indica não conformidade, dado que os documentos apresentados tratam exclusivamente da gestão e fiscalização de contratos, omitindo a fase de seleção de fornecedores. Não foram localizadas minutas de edital, checklists de seleção ou critérios de julgamento. A evidência é insuficiente. A lacuna relevante é a inexistência de artefatos padronizados para a fase de seleção;
- **E4:** A organização declarou “Sim” no subitem a) do item 2804, mas a evidência encaminhada foi considerada insuficiente para comprovar que as contratações de soluções de TI, independentemente de qual seja a área demandante, são obrigatoriamente submetidas à análise prévia e aprovação técnica da área de gestão de TI;
 - Justificativa da avaliação: A avaliação realizada indica que a evidência apresentada é insuficiente para atender ao requisito solicitado. O ‘Acordo de Cooperação Técnica 1/2024’ (páginas 1 a 10) formaliza uma parceria operacional entre a Secretaria de Estado de Transformação Digital e o Centro de Tecnologia de Informação e Comunicação do Estado do Rio de Janeiro, não instituindo, contudo, norma ou regulamento que obrigue a análise prévia e a aprovação técnica da área de gestão de TI para todas as contratações de soluções de tecnologia. Consta-se a ausência de norma interna que estabeleça esse fluxo de governança, bem como a inexistência de caso concreto que demonstre a aplicação efetiva de tal controle.

Situação encontrada

As contratações de TIC devem observar governança técnica, planejamento prévio proporcional à complexidade do objeto, participação da área de tecnologia quando cabível e critérios objetivos para recebimento e mensuração de resultados. A complexidade dos ativos de tecnologia, as exigências de conformidade legal, incluindo LGPD quando aplicável, e a dependência das atividades finalísticas em relação aos serviços de TIC demandam controles compatíveis com a relevância, o risco e o valor da contratação.

Os critérios previstos na Lei 14.133/2021, na Lei 13.709/2018 (LGPD) e nos objetivos do COBIT 2019 disciplinam que a alta administração responde pela governança das contratações, que a fase preparatória deve ser instruída com planejamento compatível com o objeto e que os Termos de Referência (TR), projetos básicos, contratos ou instrumentos equivalentes devem conter requisitos, modelos de execução, critérios de medição e parâmetros de acompanhamento proporcionais à natureza da contratação⁵.

Com base na análise das respostas aos itens 2801, 2804, 2102 e 2802 do questionário aplicado e da avaliação das evidências documentais anexadas, não foi demonstrado atendimento suficiente das contratações de TIC da organização a essas diretrizes. A Equipe de Auditoria identificou fragilidades nos seguintes aspectos:

- **Processo de contratação de TIC:** a fragilidade ou ausência de fluxo padronizado contraria a governança de contratações (Lei 14.133/2021, art. 11/art. 19, IV) e o COBIT 2019 (APO01.09), acarretando indefinição de papéis, ritos processuais e prazos internos.
- **Aprovação técnica de TIC:** a falta de avaliação prévia pela área técnica, quando necessária, contraria a governança institucional (COBIT 2019, BAI02.04 e APO01.05), favorecendo aquisições de soluções desalinhadas do ambiente tecnológico existente.

Essas situações ensejaram o presente achado e serão detalhadas nas subseções seguintes.

Processo formal e padronizado para contratações de TIC

O processo de contratação de TIC deve estabelecer fluxo, etapas, papéis, responsabilidades, modelos mínimos de artefatos, manuais, checklists ou orientações internas. Esses elementos reduzem improvisação, aumentam padronização e permitem controle sobre a qualidade da instrução processual.

O art. 11, parágrafo único, da Lei 14.133/2021 atribui à alta administração responsabilidade pela governança das contratações, com processos, estruturas, gestão de riscos e controles internos. O art. 19, inciso IV, prevê a instituição de modelos de documentos padronizados, e o COBIT 2019, APO01.09, orienta a definição e comunicação de políticas e procedimentos.

Da análise das respostas ao item 2801 e da documentação apresentada, verificou-se que a existência de processo formal e padronizado para contratações de TIC, com fluxo, etapas, papéis, responsabilidades, instâncias de aprovação e modelos de artefatos

⁵ Os critérios de contratações de TIC combinam requisitos legais da Lei 14.133/2021, requisitos de segurança e proteção de dados da LGPD e boas práticas do COBIT 2019 sobre requisitos, papéis, procedimentos, contratos e desempenho de fornecedores.

proporcionais ao porte e aos riscos das contratações, não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2801, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que o processo de trabalho para o planejamento das contratações de TI contempla as etapas, as responsabilidades dos atores envolvidos e os artefatos resultantes de cada etapa (E1);
- No subitem c) do item 2801, não houve declaração afirmativa quanto à prática avaliada: o processo de trabalho para a seleção de fornecedores contempla as etapas, as responsabilidades dos atores envolvidos e os artefatos resultantes de cada etapa (E2);
- No subitem d) do item 2801, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que são disponibilizados artefatos padronizados para a fase de seleção de fornecedores, como minutas, checklists, modelos de edital, pareceres, critérios de julgamento ou documentos equivalentes (E3).

A ausência de fluxo processual regulamentado e de modelos padronizados reduz a segurança quanto à conformidade das contratações de TIC e eleva o risco de atrasos processuais, indefinição de papéis e inconsistências na elaboração dos documentos da fase preparatória.

Análise prévia e aprovação técnica da área de TIC

As contratações de TIC devem ser submetidas à análise prévia e aprovação técnica da área de TIC, inclusive quando demandadas por outras áreas da organização. Essa análise é necessária para verificar compatibilidade técnica, segurança, integração com o ambiente existente, riscos e aderência a padrões institucionais.

O COBIT 2019, BAI02.04, orienta a obtenção de aprovação formal dos requisitos funcionais, técnicos, de segurança e de conformidade antes de prosseguir com a solução. O COBIT 2019, APO01.05, reforça a definição de papéis e responsabilidades relacionados à informação e à tecnologia. De forma complementar, o art. 1º, § 1º, da Instrução Normativa SGD/ME nº 94/2022, adotado como referência de boa prática, aponta a possibilidade de facultar a aplicação de ritos formais para contratações diretas por dispensa em razão do valor (inciso II do art. 75 da Lei nº 14.133/2021), indicando que os controles e pareceres podem ser proporcionais à relevância estratégica, complexidade e valor da aquisição.

Da análise das respostas ao item 2804 e da documentação apresentada, verificou-se que a submissão das contratações de TIC à análise prévia ou aprovação técnica da área de TIC, inclusive quando demandadas por outras áreas, não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2804, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que as contratações de soluções de TI, independentemente de qual seja a área demandante, são obrigatoriamente submetidas à análise prévia e aprovação técnica da área de gestão de TI (E4).

A ausência de análise prévia ou aprovação técnica da área de TIC reduz a segurança de que as soluções contratadas sejam compatíveis com o ambiente tecnológico existente, com os requisitos institucionais e com os controles mínimos de segurança da informação, observada a proporcionalidade em relação à complexidade, ao risco e ao valor da contratação.

Conclusão

As fragilidades evidenciadas na fase preparatória das contratações de TIC reduzem a segurança de que a organização disponha de controles suficientes para assegurar, conforme aplicável ao caso concreto, processo formal de contratação, participação técnica da área de TIC, alinhamento ao planejamento e adequada instrução dos processos. Essas fragilidades elevam o risco de contratações insuficientemente fundamentadas, pouco rastreáveis ou desalinhadas às necessidades institucionais, à complexidade e aos riscos das soluções de TIC pretendidas.

Em razão das lacunas descritas, são propostas recomendações preliminares voltadas à estruturação e à adequação dos aspectos da fase preparatória das contratações de TIC efetivamente apontados neste achado, observados os critérios aplicáveis indicados nas seções anteriores.

Propostas de Encaminhamento

- **Comunicação com Recomendação** para que formalize e padronize o processo de contratação de TIC, compatível com o porte, a complexidade e os riscos das contratações da organização, atentando-se, minimamente, em definir fluxo, etapas, papéis, responsabilidades, instâncias de aprovação e modelos de artefatos, manuais, listas de verificação ou orientações internas aplicáveis;
- **Comunicação com Recomendação** para que estabeleça a submissão das contratações de TIC à análise prévia da área de TIC, inclusive quando demandadas por outras áreas, de modo a verificar a compatibilidade da solução com os padrões tecnológicos, os requisitos institucionais, a segurança da informação e a arquitetura existente, admitindo fluxos simplificados para contratações de baixa complexidade ou baixo valor, desde que preservada análise técnica mínima compatível com o risco da contratação.

4. Plano de ação

Para facilitar o atendimento das propostas constantes da Seção 3, a Equipe de Auditoria elaborou modelo preliminar de plano de ação contendo os encaminhamentos propostos à organização. O quadro não antecipa decisão final desta Corte de Contas e poderá ser revisto após a análise dos comentários do gestor.

Cumpra registrar que, em conformidade com o art. 4º, incisos I e II, da Deliberação TCE-RJ nº 346/2024, cabe à unidade jurisdicionada avaliar a conveniência e a oportunidade de implementar as recomendações. Ressalta-se, contudo, que a eventual decisão pela não aderência deve ser motivada: o gestor deve apresentar justificativa formal que demonstre, à luz das circunstâncias do caso concreto, as razões da decisão e, quando cabível, as medidas alternativas adotadas para tratar a situação que ensejou a recomendação.

Tabela 8 - Plano de ação contendo os encaminhamentos preliminarmente propostos

Achado	Medida proposta	Avaliação de		
		Viabilidade	Quem?	Quando?
1	avale e ajuste o posicionamento organizacional da área de TIC, atentando-se, minimamente, em assegurar interlocução adequada com a alta administração e participação nas decisões estratégicas, orçamentárias, contratuais e de gestão de riscos relacionadas à tecnologia da informação			
4	avale a força de trabalho dedicada à TIC e à segurança da informação e adote medidas proporcionais para assegurar capacidade mínima de planejamento, gestão, proteção, contratação, fiscalização e sustentação dos serviços e ativos de TIC			
4	estime e mantenha atualizado o quantitativo necessário de pessoal de TIC e segurança da informação, considerando o porte e a complexidade da organização, os serviços críticos, os sistemas mantidos, as contratações vigentes e os riscos relevantes			
4	avale a necessidade de instituir cargos, funções, gratificações, perfis ou ocupações específicas de TIC e segurança da informação e adote a solução compatível com as necessidades institucionais e a capacidade administrativa da organização			
4	defina perfis profissionais mínimos para gestores e colaboradores de TIC e segurança da informação, atentando-se, minimamente, em estabelecer conhecimentos, habilidades, experiência e responsabilidades requeridos e utilizar esses perfis na seleção e designação dos responsáveis			

Achado	Medida proposta	Avaliação de		
		Viabilidade	Quem?	Quando?
4	realize diagnóstico periódico das lacunas de competências dos gestores e colaboradores de TIC e segurança da informação e estabeleça plano de tratamento, contemplando, conforme a necessidade, capacitação, realocação, provimento, apoio especializado, compartilhamento de estrutura ou contratação com transferência de conhecimento			
5	institua e mantenha atualizado catálogo de serviços de TIC, atentando-se, minimamente, em identificar os serviços efetivamente prestados, seus responsáveis, usuários, condições de acesso e informações necessárias ao atendimento das áreas demandantes			
5	defina, pactue e monitore níveis mínimos de serviço ou metas de atendimento para os serviços de TIC mais relevantes, estabelecendo indicadores, responsáveis, periodicidade de medição e forma de comunicação dos resultados			
5	formalize e execute processo de gestão de incidentes de TIC, atentando-se, minimamente, em definir papéis, responsabilidades, critérios de priorização e escalamento, tratamento de incidentes de serviços e de segurança da informação, registro sistemático e rastreável das ocorrências e análise posterior dos incidentes relevantes ou recorrentes			
6	formalize e padronize o processo de contratação de TIC, compatível com o porte, a complexidade e os riscos das contratações da organização, atentando-se, minimamente, em definir fluxo, etapas, papéis, responsabilidades, instâncias de aprovação e modelos de artefatos, manuais, listas de verificação ou orientações internas aplicáveis			
6	estabeleça a submissão das contratações de TIC à análise prévia da área de TIC, inclusive quando demandadas por outras áreas, de modo a verificar a compatibilidade da solução com os padrões tecnológicos, os requisitos institucionais, a segurança da informação e a arquitetura existente, admitindo fluxos simplificados para contratações de baixa complexidade ou baixo valor, desde que preservada análise técnica mínima compatível com o risco da contratação			

(Fonte: elaboração própria)

Apêndice A. Comparabilidade com o ciclo anterior (iGovTI 2023 vs. iGovTI 2026)

A estrutura de 2026 preservou a escala de 0 a 1, as categorias de resposta e as quatro faixas de maturidade empregadas em 2023, mas alterou de forma relevante a composição dos agregados e seus pesos. As principais diferenças estão sintetizadas na Tabela 9.

Tabela 9 - Principais diferenças entre as estruturas do iGovTI 2023 e do iGovTI 2026

Aspecto	iGovTI 2023	iGovTI 2026	Implicação analítica
Composição do índice final	Governança de TIC e Gestão de TIC com pesos iguais de 0,50.	Governança de TIC com peso 0,4777 e Gestão de TIC com peso 0,5223.	A gestão passou a ter participação ligeiramente superior no índice final.
Governança de TIC	Agregação hierárquica de ModeloTI, MonitorAvaliaTI e ResultadoTI.	Agregação direta de quatro práticas relativas ao modelo de gestão, monitoramento, auditoria interna e simplificação de serviços públicos.	O componente tornou-se mais direto e incorporou práticas com escopo distinto da estrutura anterior.
Gestão de TIC	Agregação de Planejamento de TIC, Pessoas e Processos de TIC; este último reunia serviços, níveis de serviço, riscos, segurança, software, projetos e contratos.	Agregação direta das seis dimensões de Gestão de TIC descritas neste relatório.	O índice passou a evidenciar separadamente seis capacidades operacionais e de segurança.
Pessoas e contratações	Pessoas e contratações de TIC integravam o cálculo da Gestão de TIC.	Não integram a árvore de cálculo do iGovTI 2026, embora continuem relevantes para o diagnóstico e para a auditoria.	Mudanças nessas matérias não explicam diretamente a variação do índice de 2026.
Serviços, software e projetos	Serviços e níveis de serviço eram agregados distintos; software e projetos integravam Processos de TIC.	Serviços foram consolidados na dimensão Gestão de Serviços de TIC; software e projetos foram reunidos na dimensão Gestão de Soluções de TIC.	A leitura deve considerar a nova delimitação conceitual dos componentes.

(Fonte: elaboração própria)

Em razão dessas alterações, a diferença entre os valores nominais de 2023 e 2026 não deve ser interpretada automaticamente como evolução ou retrocesso institucional. Uma análise temporal válida exige a harmonização das questões e dos agregados comparáveis, além da consideração de mudanças de escopo, pesos, respondentes e qualidade das evidências.

Para viabilizar a análise longitudinal, foram elaboradas estruturas ajustadas comparáveis para 2023 e 2026, com a manutenção apenas das práticas passíveis de correspondência entre os instrumentos e a aplicação de uma estrutura comum de agregação. Após a normalização das siglas e a validação das correspondências institucionais, foram identificadas 69 organizações presentes nos dois ciclos, equivalentes a 60,5% das organizações com respostas completas em 2026. A comparação individual foi apresentada somente para esse conjunto pareado.

Os resultados ajustados comparáveis têm finalidade exclusivamente analítica. Eles não substituem os índices oficiais de cada ciclo, não eliminam integralmente os efeitos de alterações de respondentes ou de contexto institucional e não constituem, isoladamente, evidência de conformidade ou de inconformidade.

SIGILOSO

Apêndice B. Ajustes nas respostas declaradas

A Equipe de Auditoria, em busca da melhor representação do cenário atual de governança e gestão de TIC, ajustou resposta(s) declarada(s) pela organização **SETD** ao questionário iGovTI 2026.

Para tanto, foram utilizadas as justificativas e evidências fornecidas pelo jurisdicionado quando do envio das respostas ao questionário. Ressalta-se que a verificação dessa documentação foi realizada nos termos dos procedimentos definidos para a fiscalização, de modo que nem todas as evidências encaminhadas foram, necessariamente, objeto de análise exaustiva pela Equipe de Auditoria.

Seguem as alterações realizadas após a avaliação das respostas e da amostra de evidências, bem como as justificativas apresentadas pela Equipe:

Tabela 10 - Relação de respostas ajustadas pela Equipe após validação

Questão	Resposta original	Resposta ajustada	Justificativa
q2102ext[B]	Sim	Não	O documento não apresenta evidência de publicação em sítio eletrônico público acessível à sociedade. Embora contenha links de autenticação do sistema SEI para consulta de documentos internos, não restou demonstrada a disponibilização do plano em página da internet, conforme exigido pelo critério de transparência.
q2201	Adota parcialmente.	Não adota.	A avaliação realizada indica que o documento apresentado é um Acordo de Cooperação Técnica, o qual não se configura como catálogo de serviços de TI nem estabelece instrumentos para a gestão e o monitoramento de níveis de serviço (ANS). A evidência limita-se a descrever ações de cooperação entre os órgãos, sem conter requisitos de gestão de serviços de TI exigidos pelo critério. Constatou-se a ausência de catálogo de serviços de TI estruturado e de mecanismos de acompanhamento de indicadores de desempenho.
q2201ext[A]	Sim	Não	A avaliação realizada indica que não há catálogo de serviços de TI com as metas operacionais exigidas, como prazos, horários de suporte ou pontos de contato. O documento limita-se a um cronograma de execução de ações de cooperação, sem definição de níveis de serviço voltados aos usuários. Falta a formalização de um catálogo que especifique as metas e condições de entrega dos serviços.

Questão	Resposta original	Resposta ajustada	Justificativa
q2201ext[C]	Sim	Não	A avaliação realizada indica que não é possível constatar a acessibilidade de um catálogo de serviços, visto que tal instrumento não foi apresentado. A ausência de um catálogo de serviços estruturado inviabiliza a verificação da sua disponibilidade aos usuários. Inexiste evidência de portal, sistema ou documento de acesso amplo aos usuários e às equipes de suporte.
q2201ext[E]	Sim	Não	A avaliação realizada indica que não há monitoramento contínuo de níveis de serviço (ANS) conforme exigido. As cláusulas do acordo referem-se ao acompanhamento administrativo das ações da parceria, sem contemplar indicadores de desempenho ou metas de disponibilidade de serviços de TI. Falta a comprovação de monitoramento sistemático voltado aos serviços prestados aos usuários.
q2204	Adota em maior parte ou totalmente.	Não adota.	A evidência apresentada (Acordo de Cooperação Técnica nº 1/2024) não comprova a execução de processos de gestão de incidentes de TI ou de segurança da informação. O documento limita-se a estabelecer termos de cooperação mútua para suporte técnico, infraestrutura e capacitação, sem instituir normas, registros de chamados ou fluxos de trabalho específicos para a gestão de incidentes. A evidência é insuficiente por não conter os elementos operacionais exigidos para demonstrar a existência do processo. Falta a apresentação de documento normativo ou registros operacionais, como chamados ou relatórios de atendimento.
q2204ext[A]	Sim	Não	Não há, no Acordo de Cooperação Técnica, regras ou critérios definidos para a priorização e escalamento de incidentes. O documento limita-se a estabelecer responsabilidades genéricas pela coordenação da parceria e suporte técnico. A evidência é insuficiente, pois faltam matrizes de impacto, severidade ou fluxos operacionais de escalonamento.
q2204ext[B]	Sim	Não	O documento não estabelece níveis de serviço (SLAs) nem acordos com áreas clientes para a resolução de incidentes. O texto trata apenas de cooperação institucional e disponibilização de infraestrutura, sem vincular a resolução de demandas a tempos-alvo ou metas de disponibilidade. A evidência apresentada é insuficiente para comprovar a existência de tais acordos.
q2204ext[D]	Sim	Não	O Acordo de Cooperação Técnica não constitui a formalização requerida para o processo de gestão de incidentes. Não foi apresentada norma interna, guia ou procedimento específico que defina etapas, papéis e responsabilidades para o tratamento de incidentes. A evidência é insuficiente por não apresentar o instrumento normativo do processo.

Questão	Resposta original	Resposta ajustada	Justificativa
q2204ext[E]	Sim	Não	O documento não define procedimentos ou responsabilidades quanto à notificação e tratamento de incidentes de segurança da informação. Embora existam cláusulas sobre sigilo e LGPD, não há diretrizes para ações emergenciais, escalamento ou comunicação específica para eventos de segurança. A evidência é insuficiente devido à ausência de fluxo ou norma de tratamento de incidentes de segurança.
q2204ext[F]	Sim	Não	Não constam no Acordo de Cooperação Técnica procedimentos para análise de incidentes, identificação de causas raízes ou implementação de ações corretivas. O instrumento menciona apenas a “análise dos resultados” do acordo ao fim da vigência, sem relação com a gestão de incidentes de TI ou segurança. A evidência é insuficiente por ausência de metodologia ou registros de análise pós-incidente.
q2702	Adota parcialmente.	Não adota.	A avaliação da Equipe de Auditoria indica que o item não está plenamente atendido. Embora o PEDTIC (pp. 33-34) e o Decreto 49.580/2025 estabeleçam o quadro de pessoal e competências regimentais, não foram apresentados documentos que consolidem os perfis profissionais, contemplando responsabilidades, atribuições, competências e requisitos por ocupação. A evidência é insuficiente para a demonstração da definição desses perfis. Identifica-se a ausência de uma matriz de competências ou dicionário de cargos detalhado para a área de TI.
q2702ext[D]	Sim	Não	A avaliação realizada indica que o item não está conforme. Embora a organização utilize mecanismos de transparência ativa, como o portal institucional e publicações no Diário Oficial, a evidência é insuficiente, visto que não existem perfis profissionais definidos e documentados a serem disponibilizados. A inexistência desses perfis inviabiliza a sua publicação. Não foram verificadas seções ou páginas específicas voltadas à transparência de perfis profissionais da área de TI.
q2801ext[A]	Sim	Não	A avaliação realizada indica não conformidade, uma vez que a norma apresentada foca majoritariamente na fase de gestão contratual. O PEDTIC aborda o planejamento estratégico, mas não detalha as etapas, responsabilidades ou artefatos específicos do rito de planejamento de contratações de TI. A evidência é insuficiente para sustentar a afirmação. A lacuna relevante é a ausência de um fluxo de planejamento de contratação detalhado com papéis e entregáveis por etapa.

Questão	Resposta original	Resposta ajustada	Justificativa
q2801ext[D]	Sim	Não	A avaliação realizada indica não conformidade, dado que os documentos apresentados tratam exclusivamente da gestão e fiscalização de contratos, omitindo a fase de seleção de fornecedores. Não foram localizadas minutas de edital, checklists de seleção ou critérios de julgamento. A evidência é insuficiente. A lacuna relevante é a inexistência de artefatos padronizados para a fase de seleção.
q2802ext[A]	Sim	Não	A evidência comprova a existência e publicação do PCA, contudo, não apresenta ato administrativo, ata ou resolução que demonstre a aprovação formal do Plano de Contratações Anual pela alta administração. Embora o PEDTIC mencione aprovação por comitê, trata-se de documento distinto do PCA. É necessário apresentar ato formal de aprovação específico para o PCA.
q2804[A]	Sim	Não	A avaliação realizada indica que a evidência apresentada é insuficiente para atender ao requisito solicitado. O 'Acordo de Cooperação Técnica 1/2024' (páginas 1 a 10) formaliza uma parceria operacional entre a Secretaria de Estado de Transformação Digital e o Centro de Tecnologia de Informação e Comunicação do Estado do Rio de Janeiro, não instituindo, contudo, norma ou regulamento que obrigue a análise prévia e a aprovação técnica da área de gestão de TI para todas as contratações de soluções de tecnologia. Constata-se a ausência de norma interna que estabeleça esse fluxo de governança, bem como a inexistência de caso concreto que demonstre a aplicação efetiva de tal controle.
q2501	Adota parcialmente.	Não adota.	A evidência apresentada (Decreto 48.209/2022) restringe-se à regulamentação do sistema SEI-RJ, não comprovando a execução de um processo de gestão de ativos associados à informação abrangente para toda a organização. O normativo estabelece regras operacionais, responsabilidades e controles limitados ao uso de sistema eletrônico específico. A ausência de inventário, análise de riscos e políticas de gestão aplicáveis à totalidade dos ativos de informação corporativos caracteriza a insuficiência da evidência.
q2501ext[A]	Sim	Não	O Decreto 48.209/2022 não apresenta ou remete a um inventário de ativos associados à informação da organização. O normativo disciplina o funcionamento e os usuários do sistema SEI-RJ, mas não fornece listagem, catálogo ou relação de ativos de hardware, software, dados ou documentos. É necessária a apresentação de inventário formal que contemple os ativos de informação corporativos.

Questão	Resposta original	Resposta ajustada	Justificativa
q2501ext[B]	Sim	Não	Embora o Decreto 48.209/2022 defina papéis e responsabilidades para o uso do sistema SEI-RJ, tais como usuários, pontos focais e administradores, não houve a definição formal de responsabilidades (propriedade) sobre a totalidade dos ativos de informação da organização. As atribuições elencadas limitam-se ao escopo operacional do sistema citado. Falta a comprovação de matriz de responsabilidade abrangente para os ativos de informação corporativos.
q2501ext[D]	Sim	Não	Os controles de proteção e segurança apresentados (acesso, assinatura eletrônica, auditoria de registros) são exclusivos do sistema SEI-RJ e não decorrem de um processo de gestão de ativos que garanta a proteção de todo o parque de ativos da organização. Não há demonstração de nexo causal entre o processo de gestão de ativos e os controles mencionados. Ausente comprovação de controles aplicáveis aos ativos de informação para além do sistema citado.
q2501ext[F]	Sim	Não	O Decreto 48.209/2022 constitui norma formal, porém disciplina apenas a operação do sistema SEI-RJ e não institui o processo de gestão de ativos associados à informação da organização. Não foi apresentada norma interna, guia ou instrumento similar que oriente a execução da gestão de ativos de forma transversal e institucional. É necessária a apresentação de normativo que contemple o processo de gestão de ativos de informação em âmbito corporativo.
q2701	Adota parcialmente.	Não adota.	A organização adotou parcialmente a medida, tendo formalizado a estrutura organizacional, competências das unidades e atribuições dos cargos no Regimento Interno aprovado pela Resolução SETD nº 98/2025. Contudo, não foram apresentadas evidências de perfis profissionais estruturados que incluam matrizes de competências, habilidades técnicas ou requisitos específicos além dos legais. A evidência é insuficiente por omitir a descrição detalhada do perfil requerido para o ocupante da função de gestão.
q2701ext[C]	Sim	Não	A documentação apresentada não contempla o conjunto de competências e habilidades esperadas para os ocupantes dos cargos de gestão além dos requisitos legais. O Regimento Interno limita-se a referências genéricas à formação e expertise, sem estabelecer uma matriz ou dicionário de competências técnicas e gerenciais. A evidência é insuficiente pela ausência de descrições de cargo que associem requisitos específicos à ocupação das funções.

Questão	Resposta original	Resposta ajustada	Justificativa
q2504	Adota em maior parte ou totalmente.	Não adota.	A organização não possui um Sistema de Gestão de Segurança da Informação (SGSI) formalmente definido e implementado. O relatório de conformidade (pág. 17) demonstra que a aderência total às práticas de segurança é limitada, com baixo índice de maturidade nos requisitos normativos. A ausência de um SGSI estruturado impede a correta gestão dos recursos de processamento da informação.
q2504ext[C]	Sim	Não	Embora a organização realize a atualização automática de patches de segurança, não há um processo estruturado e contínuo para a gestão de vulnerabilidades. A ausência de uma metodologia formal de monitoramento e tratamento de vulnerabilidades limita a eficácia da proteção dos ativos.
q2504ext[D]	Sim	Não	Existe uma prática operacional de configuração segura, mas ela carece de documentação formal. A ausência de registros documentais impede a verificação da conformidade e a consistência das configurações aplicadas aos ativos críticos.
q2504ext[E]	Sim	Não	A organização reconhece a existência de um processo de gestão de logs, mas este não é centralizado nem documentado formalmente. A falta de centralização e registro formal prejudica a eficácia das análises de auditoria e resposta a incidentes.
q2504ext[F]	Sim	Não	Embora a gestão de acessos privilegiados ocorra de forma centralizada, o processo não está documentado e não apresenta evidências de revisão periódica. A falta de formalização compromete o controle sobre permissões administrativas elevadas.
q2504ext[H]	Sim	Não	O ambiente de rede é gerido integralmente pelo PRODERJ, conforme documentado no Acordo de Cooperação Técnica. A SETD não apresentou evidências de que exerce controle direto ou verificação sobre a gestão de portas, protocolos e serviços em sua rede.
q2504ext[I]	Sim	Não	Similar ao controle de rede, a responsabilidade pela defesa de perímetro recai sobre o PRODERJ. Não foram apresentadas políticas próprias ou evidências de que a SETD gerencia ou supervisiona a defesa de perímetro de sua rede interna.
q2504ext[J]	Sim	Não	A organização depende da infraestrutura de backup do PRODERJ, contudo, não foram apresentadas evidências de que a SETD realiza testes periódicos de recuperação das informações, requisito essencial para assegurar a confiabilidade do backup.

Questão	Resposta original	Resposta ajustada	Justificativa
q2504ext[K]	Sim	Não	Não há um programa regular de testes de segurança ou testes de penetração (pentests). O documento apresentado é uma análise de lacunas (Gap Analysis), que constitui avaliação de conformidade, não possuindo a natureza de teste de segurança recorrente.

(Fonte: elaboração própria)

SIGILOSO